BEZPIECZEŃSTWO SYSTEMÓW TELEINFORMATYCZNYCH

Dr Hab. Inż. Mieczysław Jessa, prof. PP

Politechnika Poznańska,
Wydział Informatyki i Telekomunikacji,
ul. Polanka 3 (pok. 125), 61-131 Poznań, Poland
tel.: +48 61 665 38 54, fax: +48 61 665 38 30
e-mail: mieczyslaw.jessa@put.poznan.pl

Zakres merytoryczny przedmiotu:

Część I:

Zagrożenia dla danych przesyłanych i przetwarzanych w systemie teleinformatycznym

Część II:

Administracyjne metody ochrony danych

Część III:

Kryptograficzne metody ochrony danych

Część II
Administracyjne metody ochrony danych

1. Bezpieczeństwo instytucji a bezpieczeństwo systemów teleinformatycznych w instytucji
2. Normy i standardy w obszarze bezpieczeństwa
3. Analiza ryzyka
4. Zarządzanie ryzykiem
5. Zarządzanie bezpieczeństwem systemów teleinformatycznych
6. Audyt bezpieczeństwa teleinformatycznego

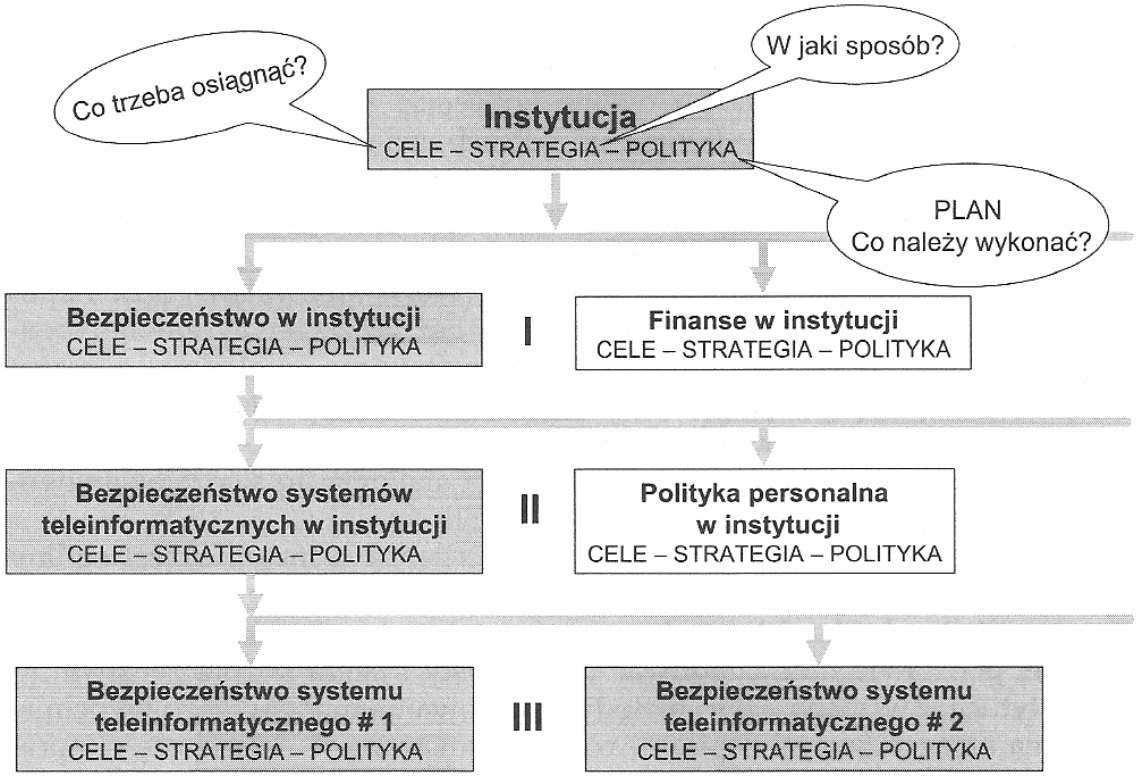
Bezpieczeństwo instytucji a bezpieczeństwo systemów teleinformatycznych w instytucji

Bezpieczeństwo systemów teleinformatycznych jest **częścią** szerszego zagadnienia jakim jest bezpieczeństwo instytucji. Punktem wyjścia do analizy bezpieczeństwa instytucji jest tzw. trójpoziomowy model hierarchii celów, strategii i polityki, określany także jako **trójpoziomowy model odniesienia**. Przedstawia on ogólną koncepcję architektury bezpieczeństwa w instytucji, wychodząc od potrzeb związanych z realizowanymi przez nią zadaniami biznesowymi lub społecznymi, po szczegóły dotyczące technologii teleinformatycznych, zasad organizacji i zachowań personelu, które temu dziełu mają służyć [1].

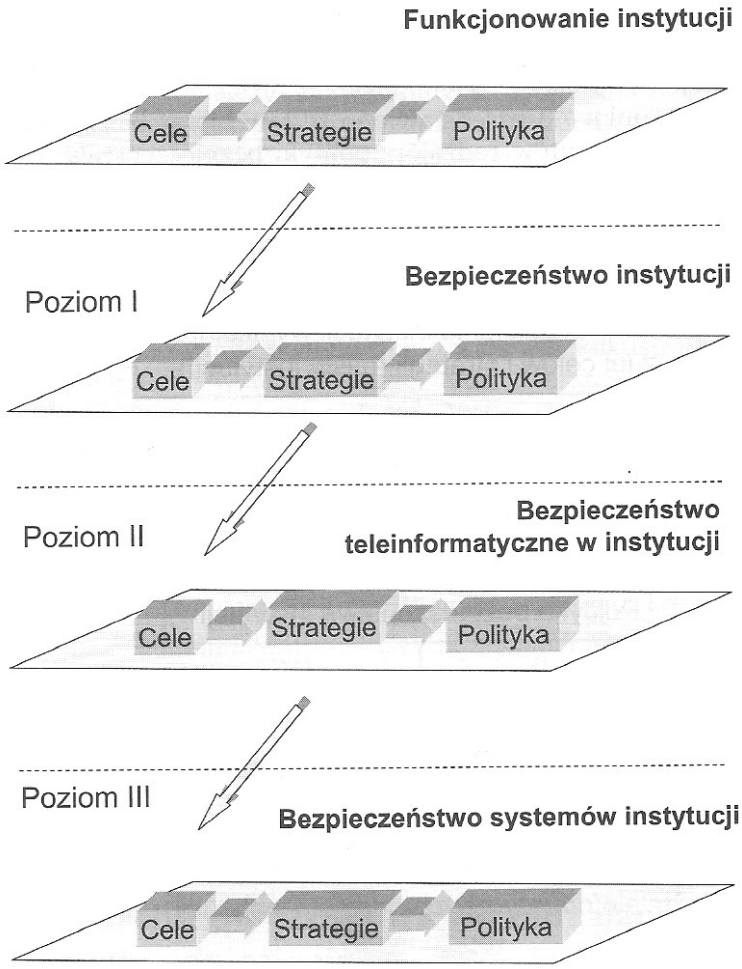
Model odniesienia w sposób **hierarchiczny** pozwala wyrazić i uporządkować bardzo różnorodne aspekty bezpieczeństwa: prawne, organizacyjne, osobowe, teleinformatyczne, fizyczne, społeczne, a nawet kulturowe i psychologiczne. To z kolei umożliwia właściwe zdefiniowanie procesów zarządzania bezpieczeństwem.

Dla każdego szczebla organizacji lub obszaru, działania instytucji mogą zostać zdefiniowane:

- Cel - identyfikuje on to, co ma być osiągnięte.
- Strategia - określa ona, jak osiągnąć wytyczony cel.
- Polityka - podaje ona, co konkretnie powinno zostać zrealizowane i jakie zasady muszą być przestrzegane.



Rys. 1. Trójpoziomowy model odniesienia [1]

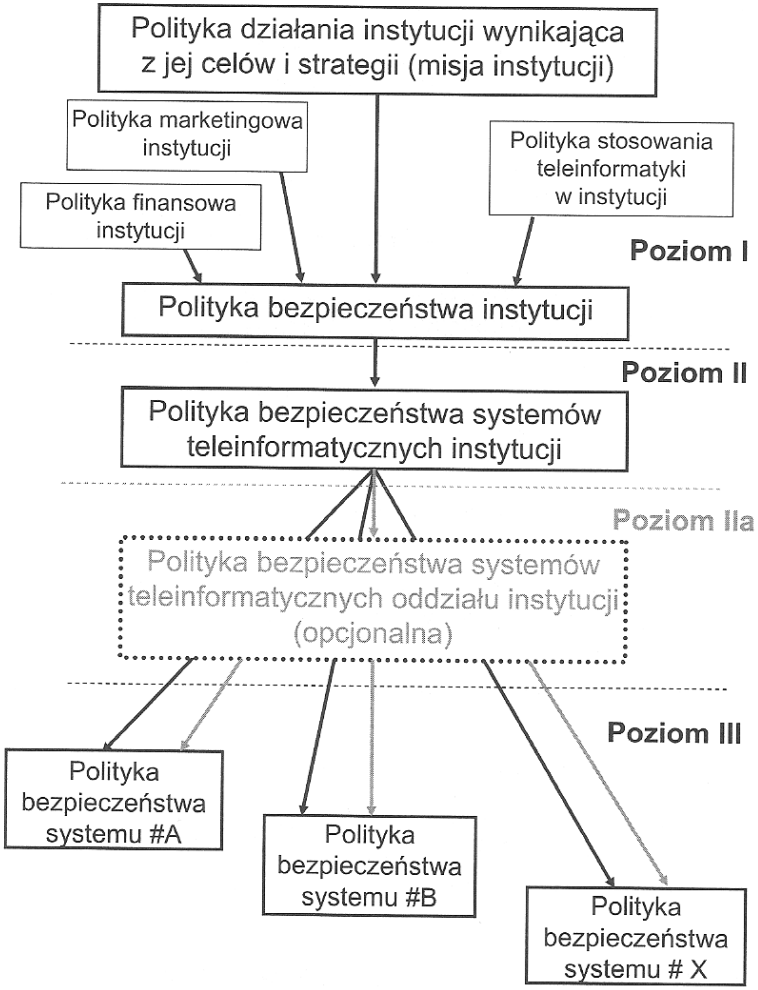


Rys. 2. Podstawowe związki między celami, strategiami i polityką w modelu trójpoziomowym [1]

W trójpoziomowym modelu odniesienia występują dwojakiego rodzaju zależności. Pierwszy typ zależności (**poziomych**) oznacza, że na danym poziomie cele są rozwijane w strategie, a te w politykę. Występują tu również zależności **pionowe**, to znaczy strategie wyższego poziomu (w kontekście związanych z nimi celów i polityki) pozwalają formułować cele poziomu niższego. Tak więc **bezpieczeństwo teleinformatyczne** instytucji jest pochodną celów, strategii i polityki w obszarze bezpieczeństwa instytucji, a ta z kolei jest pochodną celów, strategii i polityki przyjętej w instytucji, w praktyce przez zarząd tej instytucji.

Wniosek:

Bezpieczeństwo systemów teleinformatycznych jest związane ściśle z funkcjonowaniem instytucji, w szczególności z dokumentem określającym politykę bezpieczeństwa instytucji. Na jej podstawie ustalane są cele, strategię i politykę bezpieczeństwa teleinformatycznego w instytucji.



Podstawowym dokumentem wykorzystywanym w procesie tworzenia i zarządzania bezpieczeństwem jest **dokument polityki bezpieczeństwa,** która to polityka zawsze stanowi rozwinięcie strategii wynikających z jej celów. Wspomina się tam wyłącznie o hierarchii dokumentów samej polityki, odpowiadających poziomom modelu, jednak mogą w nich być zawarte także odpowiadające im strategie.

Na rysunku przedstawiono zestaw hierarchicznie uporządkowanych dokumentów rodzajów polityki bezpieczeństwa, które mogą występować w instytucji. Na pozór wynika z tego zestawu jakoby istniało wiele różnych dokumentów polityki - można podejrzewać, że nawet niespójnych. W istocie tak nie jest. W instytucji występuje **zawsze jeden** dokument polityki bezpieczeństwa - dokument polityki bezpieczeństwa instytucji. Elementem składowym tego dokumentu jest część poświęcona bezpieczeństwu systemów teleinformatycznych.

Rys. 3. Hierarchia dokumentów polityki bezpieczeństwa w instytucji [1]

Bezpieczeństwo instytucji a bezpieczeństwo systemów teleinformatycznych w instytucji

Uwaga:

Dokumenty polityki poziomów II/IIa i III z niej wynikające oraz wszelkie inne, tworzone zgodnie z potrzebami dokumenty związane, są podporządkowane dokumentowi polityki bezpieczeństwa; są one częściami dokumentu głównego lub mogą występować w postaci jego załączników. Należy zagwarantować **spójność całości dokumentacji bezpieczeństwa**, co umożliwia zarządzanie zgodnie z tą polityką [1].

Nie jest również wymagane, aby w dokumencie polityki poszczególne poziomy były wyróżniane explicite. Instytucje różnią się wielkością, rozproszeniem, różnorodnością wymagań, stąd ich dokumentacja bezpieczeństwa, zawsze optymalizowana pod względem zwięzłości i objętości, powinna te potrzeby odzwierciedlać. Oznacza to na przykład możliwość opracowania polityki trójpoziomowej, kilkustronicowej dla małej lub średniej firmy, albo rozbudowanej, zhierarchizowanej i modularnej dla korporacji międzynarodowej. Model trójpoziomowy ma charakter modelu odniesienia, który pozwala wyrazić oba te skrajne przypadki.

Polityka bezpieczeństwa instytucji wynika z polityki działania instytucji i związanych z nią innych dokumentów dotyczących różnych aspektów polityki o charakterze biznesowym: polityka marketingowa, finansowa, rozwoju, informatyzacji i tak dalej. **Na podstawie polityki bezpieczeństwa instytucji jest tworzona polityka bezpieczeństwa systemów teleinformatycznych w instytucji, na jej zaś podstawie są wypracowywane różne dokumenty polityki dla poszczególnych systemów.** Opcjonalnie dla bardzo dużych, różnorodnych i rozproszonych instytucji może istnieć potrzeba tworzenia różnych dokumentów polityki dla poszczególnych jej oddziałów, które z kolei mogą być podstawą tworzenia dokumentów polityki systemów teleinformatycznych pracujących w tych oddziałach [1].

Bezpieczeństwo instytucji a bezpieczeństwo systemów teleinformatycznych w instytucji

Celem polityki bezpieczeństwa jest stworzenie jasnych, zgodnych z prawem i przepisami wewnętrznymi oraz strategią biznesową przedsiębiorstwa **instrukcji** dotyczących szeroko rozumianego bezpieczeństwa firmy.

Większość znanych profesjonalnych metod oceny bezpieczeństwa teleinformatycznego działa na zasadzie przejścia od dołu danej organizacji do góry. Zaczynają od infrastruktury i skupiają się na technologicznych zagrożeniach i problemach (wirusy, łaty systemów operacyjnych, szyfrowanie, etc.) bez analizy zagrożeń dla misji organizacji oraz celów biznesowych. Lepszym podejściem jest przyjrzenie się samej organizacji, znalezienie elementów, które mają być chronione, określenie dlaczego są one zagrożone i wypracowanie rozwiązań zawierających aspekty technologiczne jak i systemowe. Temu celowi służy, m.in. trójpoziomowy model odniesienia celów , strategii i polityki.

Podsumowując, **całościowa metoda podejścia do oceny bezpieczeństwa powinna uwzględniać wszystkie istotne elementy, zagrożenia oraz oczekiwania klientów.** Należy użyć mechanizmów umożliwiających **priorytetyzację zagadnień** w zależności od tego, co jest istotne dla operatora a co nie. Uwzględnione powinny być także **problemy organizacyjne** związane ze sposobem używania przez ludzi infrastruktury w celu wykonania założeń biznesowych organizacji jak i **problemy techniczne** związane z konfiguracją jej pracy. Istotną jest również **elastyczność metody,** by można było ją dostosować do wielkości, struktury oraz celów danej organizacji.

Bezpieczeństwo instytucji a bezpieczeństwo systemów teleinformatycznych w instytucji

Tworzenie **jakiegokolwiek** systemu bezpieczeństwa należy rozpocząć od zapewnienia odpowiednich funduszy i utworzenia zespołu specjalistów odpowiedzialnego za rozwój, kontrolę i ocenę polityki bezpieczeństwa. Następnie zespół powinien zająć się opracowywaniem metodologii:

- wprowadzania,
- utrzymywania,
- egzekwowania,
- testowania,
- udoskonalania

mechanizmów oraz procedur związanych z bezpieczeństwem.

Zespół powinien patrzeć na zagrożenia **w kontekście tego, co organizacja chce osiągnąć i dopiero wtedy ustalić priorytety.** To prowadzi do metod, które zamiast koncentrować się na podejściu bazującym na słabych punktach, **koncentrują się na ryzyku (zagrożeniach).** Takie podejście pomaga kadrze kierowniczej zrozumieć jak bezpieczeństwo informacji wpływa na misję organizacji oraz jej cele biznesowe. Uświadamia im, **które elementy są istotne dla firmy i gdzie tkwi niebezpieczeństwo.** Na tej podstawie można dokonać oceny zagrożeń, a ponieważ te są ściśle powiązane z celami biznesowymi i misją przedsiębiorstwa **konieczne jest aktywne uczestnictwo personelu w tworzeniu szeroko rozumianego bezpieczeństwa** nie tylko technicznego, ale również zarządzającego.

Normy i standardy w obszarze bezpieczeństwa

Opracowanie mechanizmów i procedur związanych z wprowadzaniem, utrzymywaniem, egzekwowaniem, testowaniem oraz udoskonalaniem bezpieczeństwa instytucji przez powołany do tego zespół ułatwia dysponowanie adekwatnymi do potrzeb **wzorcami postępowania**. Służą temu normy i standardy z zakresu bezpieczeństwa informacji. Jest to swego rodzaju „szkielet" działań i możliwych powiązań, które mają zapewnić bezpieczeństwo na wszystkich poziomach modelu odniesienia, tj. bezpieczeństwo instytucji, bezpieczeństwo teleinformatyczne w instytucji oraz bezpieczeństwo systemów instytucji.

Obecnie istnieje bardzo wiele standardów z zakresu bezpieczeństwa. Możemy jednak je pogrupować w dwie rodziny standardów [1]:

- **oficjalne,** zwane **standardami „de jure" (inaczej normami usankcjonowanymi prawem)**, tworzone przez gremia standaryzacyjne,
- **pozostałe**, w tym tzw. **standardy „de facto" (powszechnie akceptowane wzorce lecz nie usankcjonowane prawem krajowym, regionalnym, np. UE, czy międzynarodowym)**, obejmujące zalecenia organizacji i stowarzyszeń branżowych oraz wiodących firm.

Standardy oficjalne możemy dalej podzielić na:

- międzynarodowe,
- regionalne,
- krajowe.

Normy i standardy w obszarze bezpieczeństwa

Standardy oficjalne są tworzone przez organizacje międzynarodowe, na przykład: ISO[1)], IEC[2)], ITU-T[3)], ONZ[4)].

[1)] International Organization for Standardization
[2)] International Electrotechnical Commission
[3)] International Telecommunication Union – Telecommunication Sector
[4)] Opracowano np. Standard wymiany dokumentów elektronicznych EDIFACT (Electronic Data Interchange for Administration, Commerce and Transport)

Standardy regionalne są tworzone przez organizacje międzynarodowe, na przykład: CEN[5)], ETSI[6)], NAFTA[7)], APEC[8)].

[5)] fr. Comité Européen de Normalization (European Committee for Standarization)
[6)] European Telecommunications Standards Institute
[7)] North America Free Trade Area
[8)] Asia Pacific Economic Council

Normy i standardy w obszarze bezpieczeństwa

Standardy krajowe są tworzone przez organizacje krajowe, na przykład: ANSI[9], SCC[10], NIST[11] – publikujący normy FIPS[12], CSA[13], BSI[14] lub polski PKN[15].

[9] American National Standards Institute
[10] Standards Council of Canada
[11] National Institute of Standards and Technology
[12] Federal Information Processing Standards
[13] Canadian Standards Association
[14] British Standards Institution
[15] Polski Komitet Normalizacyjny.

Pozostałe standardy to standardy *de facto.* Zostały one zaproponowane przez różne organizacje, stowarzyszenia branżowe oraz wiodące firmy. Nie mają umocowania prawnego ale znalazły powszechne uznanie i zastosowanie w obszarze szeroko rozumianego bezpieczeństwa. Przykłady to: ISACA[16], IETF[17], GAO[18], NSAA[19], BSI[20], ISOC[21] czy Basel Committee on Banking Supervision.

[16] International Systems Audit and Control Association
[17] Internet Engineering Task Force
[18] US General Accounting Office
[19] National State Auditors Association
[20] Bundesamt für Sicherheit in der Informationstechnik,
[21] Internet Society.

Normy i standardy w obszarze bezpieczeństwa

Spośród standardów o znaczeniu fundamentalnym należałoby wymienić:

- Raporty ISO/IEC TR 13335, norma ISO/IEC 17799 (BS 7799), normy ISO/IEC serii 270xy, amerykańskie dokumenty NIST oraz zalecenia COBIT stowarzyszenia ISACA - w dziedzinie zarządzania bezpieczeństwem teleinformatycznym i wzorcowych praktyk.
- Norma ISO/IEC 15408, normy ISO/IEC serii 270xy i jego popularne poprzedniki ITSEC, TCSEC/FC - w obszarze oceny zabezpieczeń (miary gwarantowanej).

Tak więc, podstawowe znaczenie dla wprowadzania, utrzymywania, egzekwowania, testowaniem oraz udoskonalania bezpieczeństwa mają dokumenty powstałe wspólnym wysiłkiem Międzynarodowej Organizacji Normalizacyjnej (ISO) i Międzynarodowej Komisji Elektrotechnicznej (IEC). Obie organizacje odwołują się do trójpoziomowego modelu odniesienia, wykazując przy tym, że **na jego podstawie można zbudować model bezpieczeństwa instytucji, następnie poddać go procesowi formalizacji, by docelowo umożliwić opracowanie komputerowych narzędzi wspomagających procesy zarządzania bezpieczeństwem.**

Istotne znaczenie dla bezpieczeństwa teleinformatycznego maja także dokumenty wydawane przez **NIST** (FIPS – Federal Information Processing Standard, SP – Special Publication), **ITU** oraz **ISOC**, szczególnie przez wchodzącą w jej skład organizację **IETF** (**Internet Engineering Task Force**) wydającą dokument RFC (Request for Comments). Warto zauważyć, że odziały ISOC działają w ponad 150 krajach, także w Polsce (http://www.isoc.org.pl/).

Normy i standardy w obszarze bezpieczeństwa

ISO oraz IEC współpracują od wielu lat w ramach Połączonego Komitetu Technicznego JTC I *(Joint Technical Committee 1),* którego podkomitet *(subcommittee)* SC 27 zajmuje się technologią i metodyką zabezpieczeń. Działają w nim 3 grupy robocze (*working group):*

WG 1 - usługi bezpieczeństwa, wymagania i wytyczne.

WG 2 - technologie zabezpieczeń.

WG 3 - kryteria oceny zabezpieczeń.

Wdrażaniem norm ISO/IEC JTC1/SC27 w Polsce zajmuje się Komitet Techniczny nr 182 do spraw „Ochrony Informacji w Systemach Teleinformatycznych" Polskiego Komitetu Normalizacyjnego, utworzony w 1994 roku.

Oprócz wiodącego w tym obszarze podkomitetu ISO/IEC JTC1/SC27, jeszcze inne grupy i komitety są zaangażowane w tworzeniu standardów dotyczących bezpieczeństwa, takie jak: SC6, SC17, ISO TC68 (bankowość), TC154, CEN TC215 (medycyna).
Ze względu na swoje przeznaczenie można wyodrębnić grupy standardów, które dotyczą [1]:

- **zarządzania bezpieczeństwem informacji i systemów teleinformatycznych;**
- **zastosowań kryptografii oraz bezpieczeństwa sieciowego;**
- **oceny zabezpieczeń teleinformatycznych.**

Normy i standardy w obszarze bezpieczeństwa

Jednym z pierwszych dokumentów, w którym zaproponowano kompleksowe podejście do bezpieczeństwem informacji jest opracowany w ISO/IEC JTC1/SC27 **Raport Techniczny** - ISO/IEC TR 13335, zwany skrótowo GMITS (*Guidelines for the Management of IT Security),* składający się z **pięciu** części [1].

ISO/IEC TR 13335-1: Wytyczne do zarządzania bezpieczeństwem systemów informatycznych (w Polsce wydana jako norma PN-I-13335-1):

- Terminologia, związki między pojęciami.
- Podstawowe modele

W pierwszej części raportu są przedstawione podstawowe pojęcia dotyczące bezpieczeństwa teleinformatycznego, takie jak: zasób, podatność, zagrożenie, następstwo, ryzyko, zabezpieczenie lub ryzyko szczątkowe. W formie prostych modeli pojęciowych są pokazane związki zachodzące między nimi. W raporcie zwraca się uwagę na wiele typów ograniczeń: finansowych, organizacyjnych, środowiskowych, czasowych, technicznych, społecznych, kulturowych, prawnych oraz osobowych, z którymi należy się liczyć przy tworzeniu systemu bezpieczeństwa instytucji. W raporcie są zawarte definicje **hierarchicznego modelu celów, strategii i polityki, pełniącego rolę modelu odniesienia.** Nieco uwagi poświęca się procesom zarządzania bezpieczeństwem, wyróżniając podstawowe trzy podprocesy: zarządzania ryzykiem z jego analizą, zarządzania zmianami i konfiguracją.

Normy i standardy w obszarze bezpieczeństwa

ISO/IEC TR 13335-2: Technika informatyczna - Planowanie i zarządzanie bezpieczeństwem systemów informatycznych (w Polsce wydana jako norma PN-I-13335-2):

- Różne podejścia do prowadzenia analizy ryzyka.
- Plany zabezpieczeń.
- Organizacja służb odpowiedzialnych za bezpieczeństwo.
- Znaczenie szkoleń i działań uświadamiających.
- Role i stanowiska pracy w instytucji związane z bezpieczeństwem.

W raporcie jest przedstawiony ogólny schemat planowania i zarządzania bezpieczeństwem systemów teleinformatycznych i są opisane poszczególne jego elementy, takie jak:

- określenie celów, strategii i polityki bezpieczeństwa;
- określenie wymagań w zakresie bezpieczeństwa;
- zidentyfikowanie i zanalizowanie zagrożeń i podatności zasobów;
- analiza ryzyka;
- dobór zabezpieczeń;
- monitorowanie procesu ich wdrażania, a potem funkcjonowania;
- przygotowanie personelu (szkolenie, uświadamianie);
- wykrywanie i reagowanie na incydenty.

Normy i standardy w obszarze bezpieczeństwa

ISO/IEC TR 13335-3: Techniki zarządzania bezpieczeństwem systemów informatycznych:

- Szczegółowe przedstawienie procesów zarządzania.
- Formułowanie trójpoziomowej polityki bezpieczeństwa.
- Rozwinięcie problematyki analizy ryzyka
- Rozwinięcie problematyki implementacji planu zabezpieczeń.
- Czynności powdrożeniowe, w tym: utrzymanie, monitorowanie i reagowanie na incydenty.

Raport **stanowi rozwinięcie tematyki przedstawionej w częściach 1 oraz 2**. Jest przedstawiona w nim cala droga, jaką powinna pokonać instytucja - od wytyczenia celów bezpieczeństwa, by mogła poprawnie funkcjonować, po szczegóły dotyczące eksploatacji zabezpieczeń, dobranych według potrzeb i wyników analizy ryzyka. Omówione są różne strategie postępowania z ryzykiem, zwłaszcza te, które **prowadzą do jego kontrolowanego ograniczania**. Raport zawiera przebieg analizy ryzyka i sposoby jego oceny, a także istotę procesów wdrożeniowych i powdrożeniowych.

Normy i standardy w obszarze bezpieczeństwa

ISO/IEC TR13335-4: Wybór zabezpieczeń:

- Klasyfikacja i charakterystyka różnych form zabezpieczeń.
- Sposoby doboru zabezpieczeń ze względu na rodzaj zagrożenia albo specyfikę systemu.
- Prezentacja szczegółowych zaleceń wynikających z norm ISO/IEC i opracowanych przez różne organizacje.

Raport dość szczegółowo przybliża tematykę doboru zabezpieczeń, zarówno tych podstawowych, jak i wynikających z analizy ryzyka. Zwrócona jest uwaga na zalety wstępnej wysokopoziomowej (ogólnej) analizy ryzyka, umożliwiającej wyróżnienie obszarów wymagających dokładnej analizy ryzyka i takich, dla których wystarcza ochrona podstawowa.

Raport zawiera **wzorcową listę wymagań dotyczących bezpieczeństwa teleinformatycznego** i na tym tle pokazuje (tabela przejść), jak te wymagania znalazły odzwierciedlenie w bardziej szczegółowych opracowaniach:

- ✓ Narodowych, to znaczy w brytyjskim: BS 7799, niemieckim: IT Grundschutz, amerykańskim: NIST Computer Security Handbook lub kanadyjskim Canadian Handbook on IT Security.
- ✓ Branżowych, to jest w telekomunikacyjnym - ETSI Baseline Security Standard Features and Mechanisms, w bankowym - ISO TC68 Information Security Guidelines oraz w medycznym - CEN TC251 Security Categorisation and Protection for Healthcare Information Systems

W części 4 raportu rozważane są, między innymi, takie zagadnienia jak:

- identyfikacja i uwierzytelnianie,
- dostęp logiczny do systemu teleinformatycznego i jego kontrola,
- ochrona przed szkodliwym oprogramowaniem,
- zarządzanie sieciami teleinformatycznymi,
- ochrona kryptograficzna,
- zabezpieczenia przed **utratą poufności,** a w szczególności przed: podsłuchem, ulotem elektromagnetycznym, szkodliwym oprogramowaniem, podszywanie się pod uprawnionego użytkownika, przekierowywaniem wiadomości, błędami oprogramowania, kradzieżami, nieautoryzowanym dostępem do komputera, danych usług i aplikacji, nieautoryzowanym dostępem do nośników,
- zabezpieczenia przed **utratą integralności**, a w szczególności przed: uszkodzeniem nośników pamięci, błędami obsługi, szkodliwym oprogramowaniem, podszywanie się pod uprawnionego użytkownika, przekierowywaniem wiadomości i manipulacjami rutingiem, błędami oprogramowania, awariami zasilania i urządzeń klimatyzacji, błędami i awariami technicznymi, błędami transmisji, nieautoryzowanym dostępem do komputera, danych usług i aplikacji, używaniem nieautoryzowanego oprogramowania i danych, nieautoryzowanym dostępem do nośników, pomyłkami użytkowników,
- zabezpieczenia przed **utratą dostępności**, a w szczególności przed: j.w. + katastrofy naturalne + przeciążenia sieci,
- zabezpieczenia przed **utratą uwierzytelniania,**
- zabezpieczenia przed **utratą niezawodności.**

Normy i standardy w obszarze bezpieczeństwa

ISO/IEC TR WD 13335-5: Zabezpieczenie dla połączeń z sieciami zewnętrznymi:

- Dobór zabezpieczeń stosowanych do ochrony styku systemów instytucji z siecią zewnętrzną

Normy i standardy w obszarze bezpieczeństwa

Punktem odniesienia dla wielu krajowych standardów w obszarze bezpieczeństwa teleinformatycznego jest **rodzina standardów brytyjskich BS 7799.** Są to standardy de jure, a więc normy**.** Firmuje je Brytyjski Instytut Standaryzacji (ang. *British Standard Institute*, BSI). Standardy opracował komitet funkcjonujący pod nazwą BSI/DISC Committee BDD/2. W skład zespołu autorskiego wchodzili przedstawiciele wielu brytyjskich organizacji, firm przemysłowych i konsultingowych, zainteresowanych stosowaniem bezpiecznych technologii teleinformatycznych. Zbiór norm funkcjonujących pod nazwą **BS 7799** jest uważany za punkt odniesienia dla wielu krajowych standardów w obszarze zarządzania bezpieczeństwem, często w relacji 1:1. Jest podstawą wielu norm z zakresu bezpieczeństwa teleinformatycznego i ochrony informacji wydawanych przez ISO/IEC w serii oznaczonej ISO/IEC 270xy. W Polsce są to normy serii PN-ISO/IEC 270xy.

Początki historii sięgają polowy lat 90 ubiegłego wieku, kiedy opublikowano pierwszy, dwuczęściowy standard BS 7799:

- **BS 7799-1: 1995** - *Code of Practice for Information Security Management - Kodeks postępowania do zarządzania bezpieczeństwem informacji,*
- **BS 7799-2: 1998** - *Specification for information security management systems (ISMS) - Specyfikacja systemów zarządzania bezpieczeństwem informacji.*

W roku 1999 opublikowano drugą wersję standardu, w roku 2002 trzecią, a w roku 2005 kolejną. W tym samym roku na bazie normy BS 7799:2005, ISO/IEC wydało pierwszy dokument z serii **ISO/IEC 270xy**.

BS 7799-1

Norma ta to swoisty katalog wzorcowych wymagań (zasad postępowania, zabezpieczeń i sposobów ich eksploatacji), **z którego każda instytucja powinna wybrać wymagania adekwatne do swych potrzeb. Za podstawowe w doborze zabezpieczeń są uznane wyniki analizy ryzyka, wskazujące na zalecaną siłę tych zabezpieczeń, która to siła decyduje głównie o ich koszcie**.

Rozdziały 1 i 2 normy mają charakter wstępny i przedstawiają filozofię dokumentu. W dziesięciu dalszych rozdziałach, numerowanych od 3 do 12, są prezentowane właściwe wymagania. Są to [1, 2, 3]:

3. Polityka bezpieczeństwa

3.1. Polityka bezpieczeństwa informacji

Cel: Ustalenie kierunków działania i wsparcie kierownictwa dla zapewnienia bezpieczeństwa informacji

- *Dokument polityki i jego zawartość*
  - *definicja bezpieczeństwa informacji*
  - *oświadczenie o intencjach kierownictwa*
  - *objaśnienie zasad polityki, standardy i wymagania zgodności*
  - *ogólne i szczególne obowiązki związane z zarządzaniem*
  - *odsyłacze do bardziej szczegółowych dokumentów*
- *Przegląd i ocena*
  - *efektywności polityki*
  - *kosztów i wpływu zabezpieczeń*
  - *efektów zmian technologicznych*

4. Organizacja bezpieczeństwa

4.1. Infrastruktura bezpieczeństwa informacji

Cel: Zarządzanie bezpieczeństwem informacji wewnątrz instytucji

- *Forum kierowania polityką bezpieczeństwa*
- *Koordynowanie bezpieczeństwa informacji*
- *Podział odpowiedzialności w dziedzinie bezpieczeństwa informacji*
- *Proces autoryzacji urządzeń służących do przetwarzania informacji*
- *Zapewnienie specjalistycznego doradztwa w dziedzinie bezpieczeństwa informacji*
- *Współpraca między instytucjami*
- *Niezależny przegląd bezpieczeństwa informacji*

4.2. Bezpieczeństwo dostępu osób trzecich

Cel: Utrzymywanie bezpieczeństwa urządzeń do przetwarzania informacji należących do instytucji oraz aktywów informacyjnych, do których dostęp mają osoby trzecie

- *Identyfikacja ryzyka wynikającego z dostępu osób trzecich*
  - *rodzaje dostępu (logiczny i fizyczny)*
  - *powody udzielania dostępu*
  - *wykonawcy działający w siedzibie instytucji*
- *Wymagania bezpieczeństwa zawarte w umowach z osobami trzecimi*

4.3. Zlecanie przetwarzania na zewnątrz

Cel: Utrzymanie bezpieczeństwa informacji w sytuacjach, gdy odpowiedzialność za jej przetwarzanie ponosi inna instytucja

- *Wymagania bezpieczeństwa w umowach zlecania na zewnątrz*

5. Klasyfikacja i kontrola aktywów

5.1. Rozliczalność aktywów, w tym ich inwentaryzacja

Cel: Utrzymanie odpowiedniej ochrony aktywów instytucji

5.2. Klasyfikacja informacji

Cel: Zapewnianie właściwego poziomu ochrony aktywów informacyjnych

- *Wytyczne w zakresie klasyfikacji*
- *Oznaczanie i postępowanie z informacją*

6. Bezpieczeństwo osobowe

6.1. Bezpieczeństwo przy określaniu zakresów obowiązków i zarządzaniu zasobami ludzkimi

Cel: Ograniczanie ryzyka błędu ludzkiego, kradzieży, oszustwa lub niewłaściwego użytkowania zasobów

- *Uwzględnianie aspektu bezpieczeństwa w zakresach obowiązków przypisanych do stanowisk*
- *Sprawdzanie kandydatów podczas naboru*
- *Umowa o zachowaniu poufności*
- *Zapisy dotyczące bezpieczeństwa w warunkach zatrudnienia*

6.2. Szkolenie użytkowników

Cel: Zapewnianie, że użytkownicy są świadomi zagrożeń i potrzeby zabezpieczenia informacji oraz przygotowani do wspierania polityki bezpieczeństwa instytucji w czasie przebiegu ich normalnej pracy

Zasady ogólne dotyczące szkolenia i kształcenia w zakresie bezpieczeństwa informacji

6.3. Reagowanie na naruszenia bezpieczeństwa i niewłaściwe funkcjonowanie systemu

Cel: Minimalizowanie uszkodzeń będących skutkiem naruszenia bezpieczeństwa i niewłaściwego funkcjonowania systemu oraz monitorowanie i wyciąganie wniosków z takich przypadków

- *Zgłaszanie przypadków naruszenia bezpieczeństwa*
- *Zgłaszanie słabości systemu bezpieczeństwa*
- *Zgłaszanie niewłaściwego funkcjonowania oprogramowania*
- *Nauka płynąca z incydentów*
- *Postępowanie dyscyplinarne*

7. Bezpieczeństwo fizyczne i środowiskowe

7.1. Obszary bezpieczne

Cel: Zapobieganie nieuprawnionemu dostępowi, uszkodzeniom i ingerencji w pomieszczenia instytucji i jej informację

- *Fizyczny obwód zabezpieczający*
- *Fizyczne zabezpieczenie wejścia*
- *Zabezpieczenie biur, pomieszczeń i urządzeń*
- *Praca w obszarach bezpiecznych*
- *Izolowane obszary dostaw i załadunku*

7.2. Zabezpieczenie sprzętu

Cel: Zapobieganie utracie, uszkodzeniu lub innym naruszeniom bezpieczeństwa aktywów oraz przerwaniu działalności biznesowej

- *Rozmieszczenie sprzętu i jego ochrona*
- *Zasilanie*
- *Bezpieczeństwo okablowania*
- *Konserwacja sprzętu*
- *Zabezpieczenia sprzętu znajdującego się poza siedzibą*
- *Bezpieczne zbywanie sprzętu lub przekazywanie do ponownego użycia*

7.3. Ogólne zabezpieczenia

Cel: Zapobieganie ujawnieniu lub kradzieży informacji oraz kradzieży urządzeń przetwarzania informacji

- *Polityka „czystego biurka" i „czystego ekranu"*
- *Wynoszenie mienia*

8. Zarządzanie systemami i sieciami

8.1. Procedury eksploatacji oraz zakresy odpowiedzialności

Cel: Zapewnianie poprawnego i bezpiecznego działania urządzeń przetwarzania informacji

- *Dokumentowanie procedur eksploatacyjnych*
- *Kontrola zmian w eksploatacji*
- *Procedury zarządzania incydentami związanymi z bezpieczeństwem*
- *Podział obowiązków*
- *Oddzielanie urządzeń w eksploatacji od przeznaczonych dla prac rozwojowych*
- *Zarządzanie urządzeniami przez zewnętrznych usługodawców*

8.2. Planowanie i odbiór systemu

Cel: Minimalizowanie ryzyka awarii systemów

- *Planowanie pojemności*
- *Odbiór systemu*

8.3. Ochrona przed szkodliwym oprogramowaniem

Cel: Zabezpieczenie integralności oprogramowania i informacji zabezpieczenia przed szkodliwym oprogramowaniem

8.4. Procedury wewnętrzne

Cel: Utrzymywanie integralności i dostępności usług przetwarzania informacji oraz usług telekomunikacyjnych

- *Zapasowe kopie informacji*
- *Dzienniki operatorów*
- *Zapisywanie w dzienniku informacji o błędach*

8.5. Zarządzanie sieciami

Cel: Zapewnianie bezpieczeństwa informacji w sieciach i ochrona infrastruktury pomocniczej

Zabezpieczenia sieci

8.6. Postępowanie z nośnikami i ich bezpieczeństwo

Cel: Zapobieganie uszkodzeniom aktywów oraz przerwom w działalności biznesowej

- *Zarządzanie wyjmowanymi nośnikami komputerowymi*
- *Niszczenie nośników*
- *Procedury postępowania z informacją*
- *Bezpieczeństwo dokumentacji systemu*

8.7. Wymiana danych i oprogramowania

Cel: Zapobieganie utracie, modyfikacji i nadużywaniu informacji wymienianych między instytucjami

- *Porozumienie dotyczące danych i oprogramowania*
- *Zabezpieczenia nośników podczas transportu*
- *Bezpieczeństwo handlu elektronicznego*
- *Bezpieczeństwo poczty elektronicznej*
- *Bezpieczeństwo elektronicznych systemów biurowych*
- *Systemy publicznie dostępne*
- *Inne formy wymiany informacji*

9. Kontrola dostępu do systemu

9.1. Potrzeby biznesowe związane z dostępem do systemu

Cel: Kontrola dostępu do informacji biznesowych

- *Polityka a potrzeby biznesowe*
- *Zasady kontroli dostępu*

9.2. Zarządzanie dostępem użytkowników

Cel: Zapobieganie nieuprawnionemu dostępowi do systemów informatycznych

- *Rejestracja użytkowników*
- *Zarządzanie przywilejami*
- *Zarządzanie hasłami użytkowników*
- *Przegląd praw dostępu użytkowników*

9.3. Zakres odpowiedzialności użytkowników

Cel: Zapobieganie nieuprawnionemu dostępowi użytkowników

- *Stosowanie haseł*
- *Pozostawianie sprzętu użytkownika bez opieki*

9.4. Kontrola dostępu do sieci

Cel: Ochrona usług sieciowych

- *Polityka dotycząca korzystania z usług sieciowych*
- *Wymuszanie dróg połączeń*
- *Uwierzytelnianie użytkowników przy połączeniach zewnętrznych*
- *Uwierzytelnianie węzłów*
- *Ochrona zdalnych portów diagnostycznych*
- *Rozdzielanie sieci*
- *Kontrola połączeń sieciowych*
- *Kontrola rutingu w sieciach*
- *Bezpieczeństwo usług sieciowych*

9.5. Kontrola dostępu do systemów operacyjnych

Cel: Ochrona przed nieuprawnionym dostępem do komputerów

- *Automatyczna identyfikacja terminalu*
- *Procedury rejestrowania terminalu w systemie*
- *Identyfikacja i uwierzytelnianie użytkowników*
- *System zarządzania hasłami*
- *Użycie systemowych programów narzędziowych (Utilities)*
- *Alarm przymusu stosowany do zabezpieczenia użytkowników*
- *Wyłączanie terminalu po określonym czasie*
- *Ograniczanie czasu trwania połączenia*

9.6. Kontrola dostępu do aplikacji

Cel: Ochrona przed nieuprawnionym dostępem do informacji przechowywanych w systemach informacyjnych

- *Ograniczenia dostępu do informacji*
- *Izolowanie systemów wrażliwych*

9.7. Monitorowanie dostępu do systemu i jego użycia

Cel: Wykrywanie nieuprawnionych działań

- *Zapisywanie informacji o zdarzeniach*
- *Monitorowanie użycia systemu*
- *Synchronizacja zegarów*

9.8. Komputery przenośne i praca na odległość

Cel: Zapewnienie bezpieczeństwa informacji podczas używania komputerów przenośnych i systemów do pracy na odległość

- *Komputery przenośne*
- *Praca na odległość (telepraca)*

10.Rozwój i utrzymanie systemu

10.1. Wymagania dotyczące bezpieczeństwa systemów

Cel: Zapewnienie, że bezpieczeństwo zostało „wbudowane" w systemy informacyjne

- *Analiza i opis wymagań dotyczących bezpieczeństwa*

10.2. Bezpieczeństwo systemów aplikacji

Cel: Ochrona przed utratą, modyfikacją lub nadużyciem danych użytkownika w systemach aplikacji

- *Potwierdzanie ważności danych wejściowych*
- *Kontrola wewnętrznego przetwarzania*
- *Uwierzytelnianie wiadomości*
- *Potwierdzanie ważności danych wyjściowych*

10.3. Zabezpieczenia kryptograficzne

Cel: Ochrona poufności, autentyczności i integralności informacji

- *Polityka używania zabezpieczeń kryptograficznych*
- *Szyfrowanie*
- *Podpisy cyfrowe*
- *Usługi niezaprzeczalności*
- *Zarządzanie kluczami*
  - *ochrona kluczy kryptograficznych*
  - *standardy, procedury i metody*

10.4. Bezpieczeństwo plików systemowych

Cel: Zapewnianie, że projekty informatyczne oraz działalność pomocnicza są prowadzone w bezpieczny sposób

- *Kontrola eksploatowanego oprogramowania*
- *Ochrona systemowych danych testowych*
- *Kontrola dostępu do bibliotek programów źródłowych*

10.5. Bezpieczeństwo procesów rozwojowych i obsługi informatycznej

Cel: Utrzymywanie bezpieczeństwa informacji oraz oprogramowania użytkowego

- *Procedury kontroli zmian*
- *Techniczny przegląd zmian w systemie operacyjnym*
- *Ograniczenia dotyczące zmian w pakietach oprogramowania*
- *Ukryte kanały i konie trojańskie*
- *Prace rozwojowe nad oprogramowaniem powierzone firmie zewnętrznej*

11. Zarządzanie ciągłością działania

11. 1. Aspekty zarządzania ciągłością działania

Cel: Przeciwdziałanie przerwom w działalności biznesowej oraz ochrona krytycznych procesów biznesowych przed rozległymi awariami lub katastrofami

- *Proces zarządzania ciągłością działania*
  - *zrozumienie ryzyka*
  - *zrozumienie wpływu przerw na działalność biznesową*
  - *rozważenie wykupienia odpowiedniego ubezpieczenia*
  - *sformułowanie i opisanie strategii ciągłości działania*
  - *sformułowanie i opisanie planów dla tej strategii*
  - *regularne testowanie i aktualizowanie przyjętych planów*
  - *zapewnienie, że zarządzanie ciągłością działania zostało włączone w procesy i strukturę instytucji*
- *Ciągłość działania i analiza skutków jej braku dla procesów biznesowych*
- *Tworzenie i wdrażanie planów ciągłości działania*
  - *rozpoznanie i uzgodnienie zakresów odpowiedzialności i procedur awaryjnych*
  - *wdrożenie procedur awaryjnych*
  - *dokumentacja uzgodnionych procedur i procesów*
  - *odpowiednie przeszkolenie personelu w zakresie uzgodnionych awaryjnych procedur i procesów*
  - *testowanie i aktualizacja tych planów*

- *Struktura planowania ciągłości działania*
  - *warunki uruchomienia planów*
  - *procedury awaryjne*
  - *ustalenia dotyczące kontaktów z mediami i współpracy z władzami*
  - *procedury przywracania do stanu normalnego*
  - *procedury wznowienia działalności biznesowej w miejscu rezerwowym*
  - *harmonogram utrzymania*
  - *działania edukacyjne i podnoszące świadomość - zrozumienie procesów ciągłości działania*
  - *obowiązki poszczególnych osób*
- *Testowanie, utrzymywanie i ponowna ocena planów ciągłości działania*
  - *testowanie planów na „papierze", symulacje, sprawdzenie możliwości technicznych itp.*
  - *utrzymywanie planów i ponowna ich ocena*

12. Zgodność

12.1. Zgodność z przepisami prawnymi

Cel: Unikanie naruszania jakichkolwiek przepisów prawa karnego lub cywilnego, zobowiązań wynikających z ustaw, zarządzeń lub umów i jakichkolwiek wymagań bezpieczeństwa

- *Określenie (identyfikacja) odpowiednich przepisów prawnych*
- *Prawo własności intelektualnej - prawa autorskie, w tym dotyczące oprogramowania*
- *Zabezpieczenie dokumentów instytucji*
- *Ochrona danych osobowych i prywatności informacji dotyczących osób fizycznych*
- *Zapobieganie nadużywaniu urządzeń przetwarzających informacje*
- *Regulacje dotyczące zabezpieczeń kryptograficznych*

- *Gromadzenie materiału dowodowego*
  - *zasady rządzące materiałem dowodowym*
  - *możliwość uznania materiału dowodowego*
  - *jakość i kompletność materiału dowodowego*

12.2. Przeglądy polityki bezpieczeństwa i zgodności technicznej

Cel: Zapewnianie zgodności systemów ze standardami i politykami bezpieczeństwa danej instytucji

- *Zgodność z polityką bezpieczeństwa*
- *Sprawdzenie zgodności technicznej*

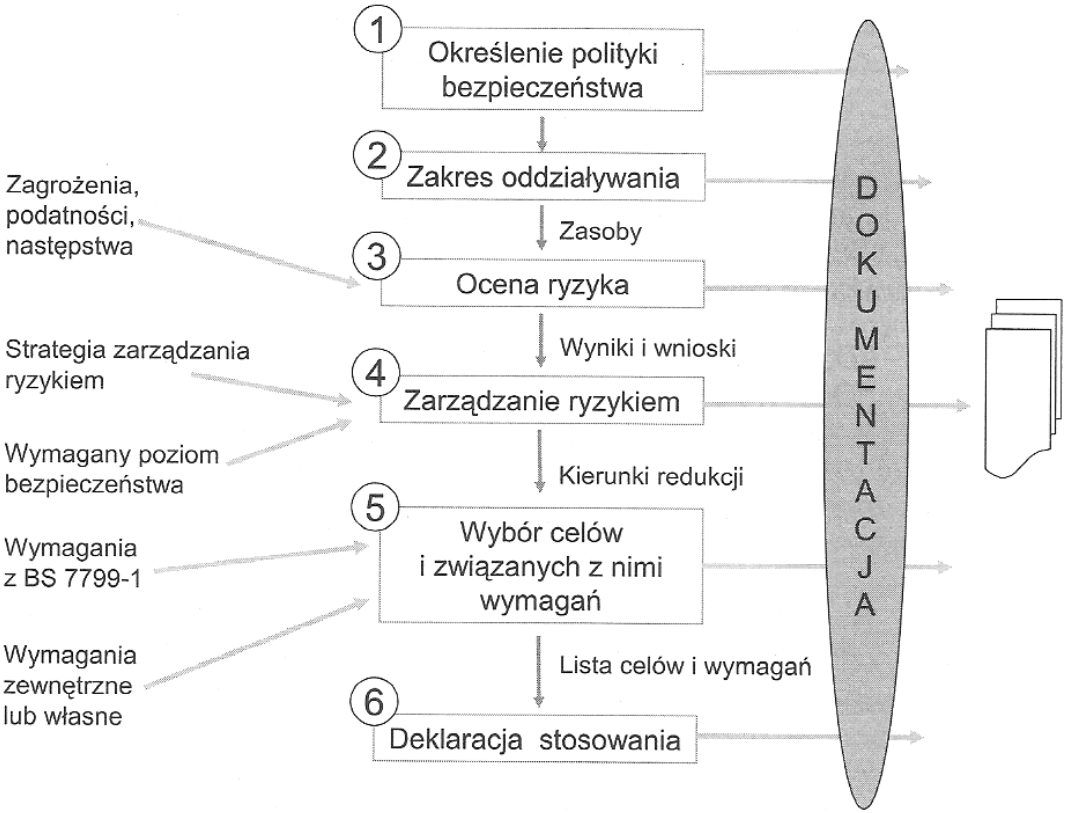
12.3. Rozważania dotyczące audytu systemu

Cel: Maksymalizowanie efektywności i minimalizowanie ingerencji w proces audytu systemu lub oddziaływania audytu na system

- *Zabezpieczenia audytu systemu*
- *Ochrona narzędzi audytu systemu*

BS 7799-2

Ta cześć zawiera wytyczne, jak zaprojektować, wdrożyć, eksploatować i poddać certyfikacji system zarządzania bezpieczeństwem informacji **ISMS** (*ang.* Information Security Management System, *pol*. System zaradzania bezpieczeństwem informacji **SZBI**). Wyróżnia się sześć etapów jego budowy.



Rys. 4. Podstawowy system zarzadzania bezpieczeństwem informacji ISMS według normy BS 7799-2 z roku 1999

Normy i standardy w obszarze bezpieczeństwa

Krok 1. Określenie polityki bezpieczeństwa:

- Dlaczego bezpieczeństwo informacji jest ważne dla instytucji?
- Jakich potencjalnych zagrożeń należy się obawiać?
- Jakie są potrzeby w zakresie poufności, integralności i dostępności?
- Jakie ryzyko instytucja jest w stanie zaakceptować?
- Jakie ograniczenia występują? Jaka jest ich natura?

Krok 2. Określenie zakresu objętego systemem ISMS:

- Czy cała instytucja ma zostać objęta systemem ISMS, czy tylko jej wybrane obszary funkcjonowania?
- Jakie są ich granice fizyczne (systemy i ich otoczenie) i logiczne (podział według usług) tych obszarów?

Krok 3. Przeprowadzenie oceny ryzyka:

- Identyfikacja zagrożeń dla zasobów.
- Analiza podatności.
- Określenie następstw.
- Oszacowanie ryzyka.

Normy i standardy w obszarze bezpieczeństwa

Krok 4. Zarządzanie ryzykiem:

- Ustalenie wytycznych co do wyboru zabezpieczeń, na podstawie potrzeb zapisanych w polityce bezpieczeństwa oraz na podstawie rezultatów analizy ryzyka.

Krok 5. Wybór celów zabezpieczeń i punktów kontrolnych (wybór wymagań z BS 7799-1):

- Wybór wymagań, od których należy zacząć budowę ISMS.
- Wybór wymagań, które są wspólne dla wszystkich instytucji.
- Wybór wymagań odzwierciedlających specyfikę potrzeb danej instytucji.

Krok 6. Wydanie postanowień o zastosowaniu każdego punktu kontrolnego (deklaracja stosowania):

- Uzasadnienie, dlaczego dane wymaganie wybrano dla instytucji albo je odrzucono.
- Dla każdego wybranego wymagania, podanie sposobu jego:
  - implementacji;
  - dokumentowania;
  - gromadzenia informacji o jego eksploatacji (w postaci tak zwanych zapisów ISMS).

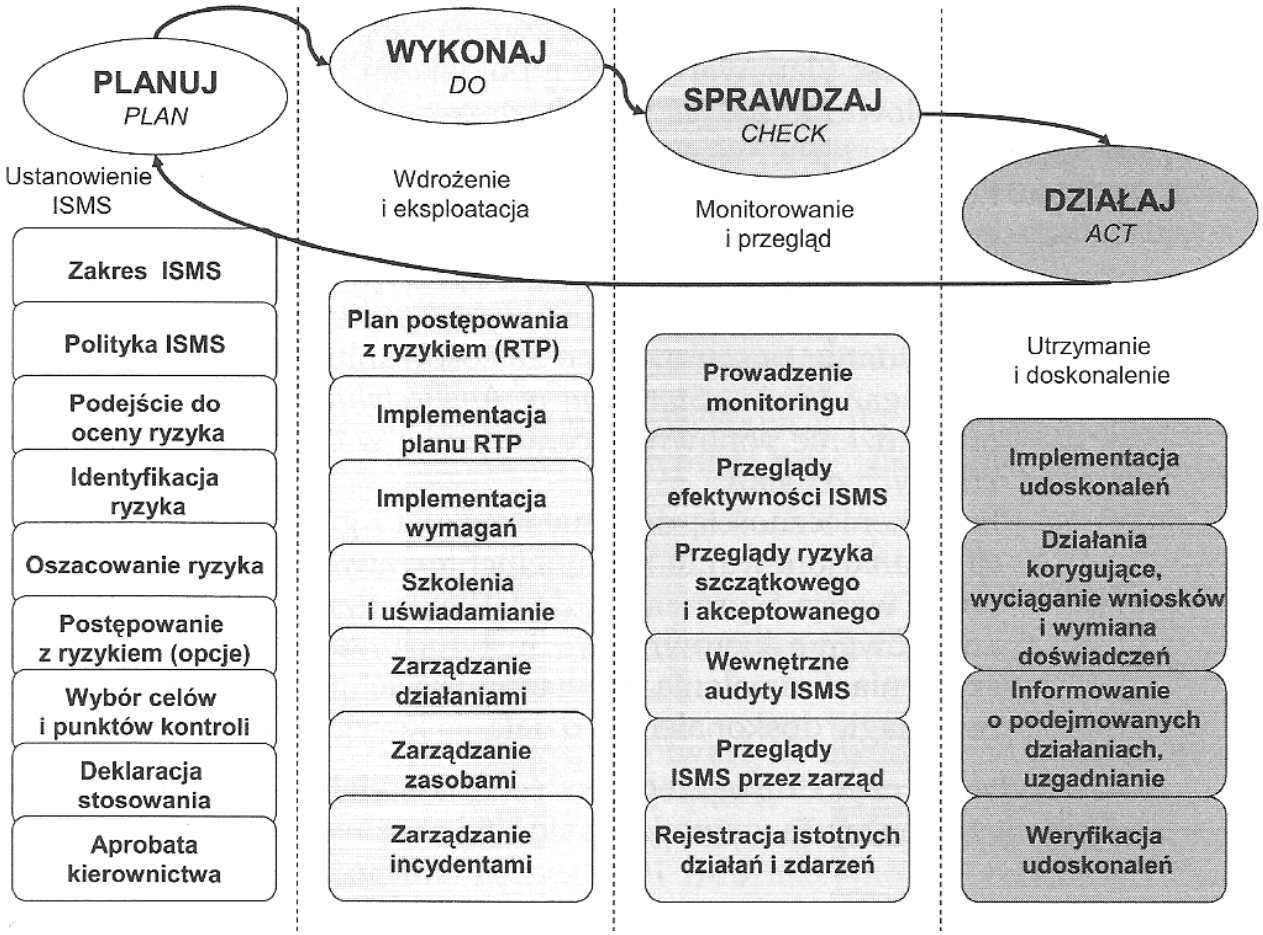
Normy i standardy w obszarze bezpieczeństwa

W 2002 roku pojawiło się nowsze wydanie normy z 1999 roku jako: **BS 7799-2:2002.** W normie BS 7799-2:2002 jest **zapewniona zgodność z normami zarządzania jakością EN ISO 9001 i środowiskiem EN ISO 14001, z dyrektywą OECD dotyczącą bezpieczeństwa teleinformatycznego**, a przede wszystkim w stosunku do pierwowzoru norma została poważnie zmodyfikowana i rozszerzona. Jako pomocniczą dla nich normę terminologiczną wskazuje się ISO Guide 73. Wprowadzona została precyzyjna definicja ISMS.

Definicja 1

System zarządzania bezpieczeństwem informacji SZBI to część całościowego systemu zarządzania instytucji, oparty na podejściu wynikającym z ryzyka biznesowego i odnoszący się do ustanawiania, wdrażania, monitorowania, utrzymywania oraz doskonalenia bezpieczeństwa informacji.

Norma z 2002 roku po raz pierwszy wprowadza **schemat ogólny zarządzania bezpieczeństwem informacji** w instytucji.



Rys. 5. Schemat ogólny zarządzania bezpieczeństwem informacji według normy **BS 7799-2:2002**

Norma wprowadza do rozbudowanego schematu zarządzania o nazwie: **PLANUJ - WYKONAJ - SPRAWDZAJ - DZIAŁAJ** (***PDCA: PLAN -DO - CHECK - ACT***), co w praktyce wiąże się ze znacznym rozszerzeniem działań objętych normą, **gdyż 6 kroków, wymienionych przy opisywaniu starszej normy, to teraz zaledwie etap PLANUJ** (Produktem końcowym jest dokumentacja).

W dokumencie większy nacisk jest położony na zarządzanie ryzykiem i bardziej szczegółowo jest przedstawiony jego zalecany przebieg. W starszej wersji istniał wymóg szacowania ryzyka i zarządzania ryzykiem, bez podania dodatkowych zaleceń. W nowej wersji zwrócono uwagę na wybór metody oszacowania ryzyka dogodnej dla instytucji i jej systemu ISMS oraz na konieczność wyznaczenia obszaru ryzyka, który dotyczy instytucji *(applicable risk)* i powinien być pod kontrolą; pomocne do tego mogą się okazać proste diagramy wyrażające ryzyko w funkcji częstości występowania niekorzystnego zdarzenia i wielkości jego następstw). Pojawiło się także pojęcie **postępowania z ryzykiem** *(risk treatment),* które polega na wyborze i wdrożeniu środków zmieniających ryzyko. Pojęcie to ma dość szerokie znaczenie i dotyczy takich kwestii, jak: *czy już akceptować ryzyko, licząc na skuteczność procedur wykrywania incydentów, czy transferować ryzyko albo zastosować dodatkowe punkty jego kontroli, czyli w efekcie dodatkowe zabezpieczenia;* zwraca się przy tym uwagę na konieczność planowania tego typu działań. Po wydaniu postanowień o zastosowaniu punktów kontroli - wymagań (SoA - *Statement of Applicability),* zaleca się przeprowadzenie ponownej oceny ryzyka w celu weryfikacji skutków tych działań. Poza koniecznością dokumentowania i gromadzenia informacji o funkcjonowaniu zaimplementowanych punktów kontroli, nowa wersja wprowadza dodatkowe działania, takie jak: **zaangażowanie kierownictwa instytucji**, zarządzanie zasobami, szkolenia i działania uświadamiające, przeglądy kierownictwa, ciągłe doskonalenie i działania korygujące.

Foreword
0 Introduction
1 Scope
2 Normative references
3 Terms and definitions,
4 Context of the organization
4.1 Understanding the organization and its context
4.2 Understanding the needs and expectations of interested parties
4.3 Determining the scope of the information security management system
4.4 Information security management system
5 Leadership
5.1 Leadership and commitment
5.2 Policy
5.3 Organizational roles, responsibilities and authorities
6 Planning
6.1 Actions to address risks and opportunities
6.2 Information security objectives and planning to achieve them
7 Support
7.1 Resources
7.2 Competence
7.3 Awareness
7.4 Communication
7.5 Documented information
8 Operation
8.1 Operational planning and control
8.2 Information security risk assessment
8.3 Information security risk treatment
9 Performance evaluation
9.1 Monitoring, measurement, analysis and evaluation
9.2 Internal audit
9.3 Management review
10 Improvement
10.1 Nonconformity and corrective action
10.2 Continual improvement
Annex A (normative) Reference control objectives and controls
Bibliography

Na bazie normy BS 7799:2005, ISO/IEC wydało pierwszy dokument z serii **ISO/IEC 270xy.** Odpowiednikiem dokumentu **BS 7799-2** jest dokument ISO/IEC 27001. Natomiast odpowiednikiem dokumentu **BS 7799-1** został dokument ISO/IEC 27002.

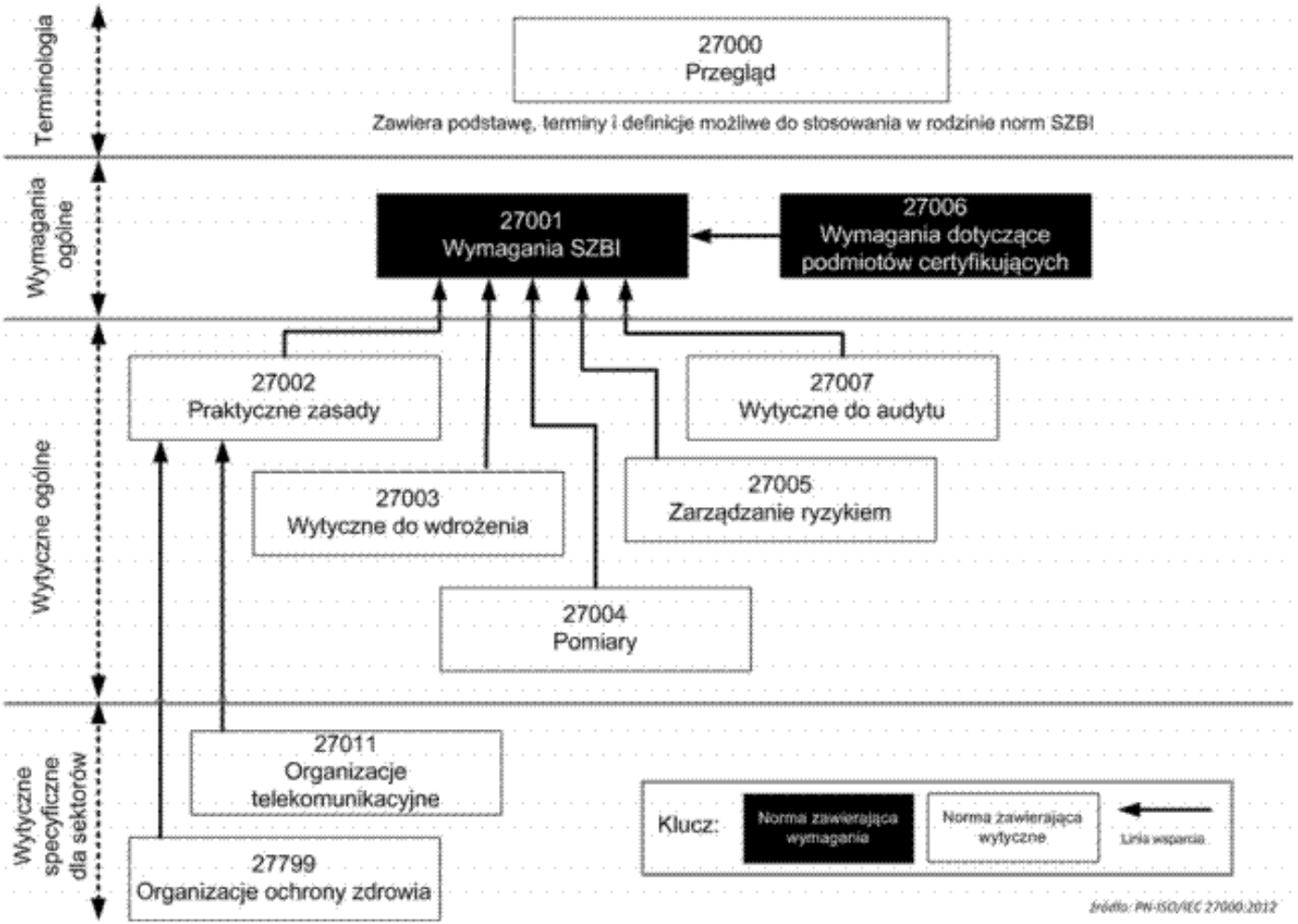
Struktura normy ISO/IEC 27001:2013

Contents

Page
Foreword
0 Introduction
1 Scope
2 Normative references
3 Terms and definitions
4 Structure of this standard
4.1 Clauses
4.2 Control categories
5 Information security policies
5.1 Management direction for information security
6 Organization of information security
6.1 Internal organization
6.2 Mobile devices and teleworking
7 Human resource security
7.1 Prior to employment
7.2 During employment
7.3 Termination and change of employment
8 Asset management
8.1 Responsibility for assets
8.2 Information classification
8.3 Media handling
9 Access control
9.1 Business requirements of access control
9.2 User access management
9.3 User responsibilities
9.4 System and application access control
10 Cryptography
10.1 Cryptographic controls
11 Physical and environmental security
11.1 Secure areas
11.2 Equipment
12 Operations security
12.1 Operational procedures and responsibilities
12.2 Protection from malware
12.3 Backup
12.4 Logging and monitoring
12.5 Control of operational software
12.6 Technical vulnerability management
12.7 Information systems audit considerations
13 Communications security
13.1 Network security management
13.2 Information transfer
14 System acquisition, development and maintenance
14.1 Security requirements of information systems
14.2 Security in development and support processes
14.3 Test data
15 Supplier relationships
15.1 Information security in supplier relationships
15.2 Supplier service delivery management
16 Information security incident management
16.1 Management of information security incidents and improvements
17 Information security aspects of business continuity management
17.1 Information security continuity
17.2 Redundancies
18 Compliance
18.1 Compliance with legal and contractual requirements
18.2 Information security reviews
Bibliography

Struktura normy ISO/IEC 27002:2013

W styczniu 2007 roku Polski Komitet Normalizacyjny wydał pierwszą wersję normy **ISO/IEC 27001**, którą oznaczono **PN-ISO/IEC 27001.** Obecnie dostępne są polskie odpowiedniki wielu norm serii ISO/IEC 270xy (rysunek ze strony PKN).



Normy i standardy w obszarze bezpieczeństwa

Wybrane normy z rodziny 27000:

- PN-ISO/IEC 27000:2014-11 – Technika informatyczna — Techniki bezpieczeństwa — Systemy zarządzania bezpieczeństwem informacji — Przegląd i terminologia; PN-EN ISO/IEC 27000:2017-06; zastąpiona przez PN-ISO/IEC 27000:2020-07 – wersja angielska.
- PN-ISO/IEC 27001:2014-12 – Technika informatyczna — Techniki bezpieczeństwa — Systemy zarządzania bezpieczeństwem informacji — Wymagania; zastąpiona normą PN-ISO/IEC 27001:2017-06.
- PN-ISO/IEC 27002:2014-12 (*wcześniej: ISO/IEC 17799*) – Technika informatyczna — Techniki bezpieczeństwa — Praktyczne zasady zabezpieczania informacji; zastąpiona normą PN-EN ISO/IEC 27002:2017-06.
- PN-ISO/IEC 27005:2014-01 – Technika informatyczna — Techniki bezpieczeństwa — Zarządzanie ryzykiem w bezpieczeństwie informacji; zastąpiona normą PN-ISO/IEC 27005:2018;
- ISO/IEC 27007:2020 –Information security, cybersecurity and privacy protection — Guidelines for information security management systems auditing.
- ISO/IEC 27011:2016 **–** Information technology — Security techniques — Code of practice for Information security controls based on ISO/IEC 27002 for telecommunications organizations.

Analiza ryzyka

Termin „ryzyko”, jest definiowany różnie, choć podobnie. Na przykład „Nowy słownik języka polskiego” (PWN, Warszawa, 2003) określa ryzyko jako:

możliwość niepowodzenia, straty; takie: działanie, które może przynieść takie skutki.

Czterotomowa „Encyklopedia powszechna” (PWN, Warszawa, 1987) określa ryzyko jako pojęcie z dziedziny prawa:

(...) w prawie cywilnym niebezpieczeństwo powstania szkody obciążające osobę bezpośrednio poszkodowaną, chyba że umowa lub przepis prawny zobowiązuje inną osobę do wyrównania szkody (...) ; szczególnie na zasadzie ryzyka opiera się odpowiedzialność za szkody wyrządzone w związku z użyciem sił przyrody(...) W prawie karnym działanie w granicach dopuszczalnego ryzyka może stanowić ustawową lub poza- ustawową okoliczność wyłączającą odpowiedzialność karną sprawcy.

Według normy IEC 61508, wiążącej pojęcie ryzyka z pojęciem hazardu:

(...) *ryzyko jest miarą stopnia zagrożenia, wyrażającą zarówno stopień szkodliwości hazardu, jak i prawdopodobieństwo jego wystąpienia.*

a według normy PN-I-13335-1:1999 bazującej na raporcie ISO/IEC TR 13335-1:

(...) ryzyko jest prawdopodobieństwem określającym możliwość wykorzystania określonej podatności przez dane zagrożenie w celu spowodowania straty lub zniszczenia zasobu lub grupy zasobów, a przez to negatywnego bezpośredniego lub pośredniego wpłynięcia na instytucję.

Według normy PN-ISO/IEC-27005:2010 ryzyko to:

(...) *potencjalna sytuacja, w której określone zagrożenie wykorzysta podatność aktywów lub grupy aktywów, powodując w ten sposób szkodę dla organizacji.*

Ryzyko jest mierzone jako kombinacja prawdopodobieństwa zdarzenia i jego następstw.

Analiza ryzyka

Słowo „ryzyko” ma zatem wiele odcieni znaczeniowych. W każdym z nich jednak wiąże się z pojęciem straty, co jest zgodne również z intuicyjnym rozumieniem tego terminu - tam, gdzie mamy do czynienia z zyskami, mówi się raczej o szansie, a nie o ryzyku (jest program TV „Szansa na sukces”, a nie „Ryzyko sukcesu”, mówimy o szansie wygrania w totolotka, a nie o ryzyku wygrania itp.). Dla potrzeb bezpieczeństwa informacji definicję podaną w normie PN-ISO/IEC-27005: można przystosować następująco:

Definicja 1

Termin **„ryzyko”** oznacza miarę stopnia zagrożenia dla tajności, integralności i dostępności informacji, wyrażoną jako iloczyn **prawdopodobieństwa** (lub możliwości) wystąpienia sytuacji stwarzającej takie zagrożenie i stopnia szkodliwości jej skutków **(strat).**

W praktyce stosowane jest też często pojęcie „ryzyka operacyjnego“. Jest ono szczególnie popularne w instytucjach typu finansowego, gdzie za Bazylejskim Komitetem ds. Nadzoru Bankowego przyjmuje się, że **ryzyko operacyjne** należy rozumieć jako ryzyko straty wynikającej z niedostosowania lub zawodności wewnętrznych procesów, ludzi i systemów technicznych lub ze zdarzeń zewnętrznych. W zakres ryzyka operacyjnego wchodzi ryzyko prawne, natomiast wyłącza się z niego ryzyko reputacji i strategiczne. Należy jednak odnotować, że w analizie ryzyka w zastosowaniach finansowych operuje się zarówno zyskami, jak i stratami [1].

Analiza ryzyka

Ocena ryzyka szeroko rozumianego bezpieczeństwa jest procesem, który warunkuje osiągnięcie celów nakreślonych normami. Przeprowadzona dobrze prowadzi do stworzenia całościowego dla danej organizacji obrazu stanu bezpieczeństwa. **Jest to więc punkt wyjścia (podstawa), która może być użyta by skupić się na łagodzeniu skutków zagrożeń oraz na ulepszeniach w ochronie przed zagrożeniami i ich skutkami**. **Okresowo ta podstawa musi być uaktualniana przez przeprowadzenie kolejnej oceny.** Okres między kolejnymi ocenami ryzyka może być określony na stałe (np. co rok) lub też kolejna ocena może być wykonana w wyniku większych zmian w firmie (np. zmiana infrastruktury IT, fuzja z inna organizacją itp.).

Podstawowe standardy wykorzystywane w analizie ryzyka to:

- Rodzina norm ISO:
  - ISO 31000:2009: *Zarządzanie ryzykiem. Zasady i wytyczne (Risk management, Principles and Guidelines),*
  - ISO31010: 2009: *Zarządzanie ryzykiem. Metody szacowania ryzyka (Risk management. Risk assessment techniques),*
  - *ISO Guide 73: 2009: Zarządzanie ryzykiem. Słownictwo. Wytyczne dla standardów (Risk management. Vocabulary. Guidelines for use in standards).*
- Standardy FIPS/NIST. Dokumentem podstawowym jest NIST SP-800-30: *Guide for Conducting Risk Assessment.*
- Polskie normy, zwłaszcza norma PN-ISO/IEC 27005:2010: *Technika informatyczna. Techniki bezpieczeństwa. Zarządzanie ryzykiem w bezpieczeństwie informacji.*

Spis treści

Przedmowa

Wprowadzenie

1. Zakres normy
2. Powołania normatywne
3. Terminy i definicje
4. Struktura niniejszej Normy Międzynarodowej
5. Informacje podstawowe
6. Przegląd procesu zarządzania ryzykiem w bezpieczeństwie informacji
7. Ustanawianie kontekstu
   - 7.1. Rozważania ogólne
   - 7.2. Podstawowe kryteria
   - 7.3. Zakres i granice
   - 7.4. Organizacja zarządzania ryzykiem w bezpieczeństwie informacji
8. Szacowanie ryzyka w bezpieczeństwie informacji
   - 8.1. Ogólny opis szacowania ryzyka w bezpieczeństwie informacji
   - 8.2. Analiza ryzyka
     - 8.2.1. Identyfikowanie ryzyka
     - 8.2.2. Estymacja ryzyka
   - 8.3. Ocena ryzyka
9. Postępowanie z ryzykiem w bezpieczeństwie informacji
   - 9.1. Ogólny opis postępowania z ryzykiem
   - 9.2. Redukowanie ryzyka
   - 9.3. Zachowanie ryzyka
   - 9.4. Unikanie ryzyka
   - 9.5. Transfer ryzyka
10. Akceptowanie ryzyka w bezpieczeństwie informacji
11. Informowanie o ryzyku w bezpieczeństwie informacji
12. Monitorowanie i przegląd ryzyka w bezpieczeństwie informacji
    - 12.1. Monitorowanie i przegląd czynników ryzyka
    - 12.2. Monitorowanie, przegląd i doskonalenie zarządzania ryzykiem

Załącznik A (informacyjny). Definiowanie zakresu i granic procesu zarządzania ryzykiem w bezpieczeństwie informacji

Załącznik B (informacyjny). Identyfikowanie i wartościowanie aktywów oraz szacowanie skutków

Załącznik C (informacyjny). Przykłady typowych zagrożeń

Załącznik D (informacyjny). Podatności i metody szacowania podatności

Załącznik E (informacyjny). Podejścia do szacowania ryzyka w bezpieczeństwie informacji

Załącznik F (informacyjny). Ograniczenia przy redukowaniu ryzyka

Bibliografia

Struktura normy PN-ISO/IEC 27005:2010

Analiza ryzyka

Ogólnie metody oceny ryzyka zostały podzielone na [1]:

- **Metody jakościowe (*qualitative*)** - wyniki uzyskuje się w postaci określeń typu: ryzyko niskie, średnie, większe niż..., podobne jak..., aczkolwiek sam proces analizy związków przyczynowo-skutkowych może być dość szczegółowy.
- **Metody ilościowe (*quantitative)*** - wyniki uzyskuje się w konkretnych jednostkach miary, zwykle w kwotach pieniężnych, powstałych z pomnożenia wielkości prawdopodobieństwa niekorzystnego zdarzenia i potencjalnych strat; prawdopodobieństwo pełni rolę współczynnika wagowego.

W obu metodach mówimy o **szacowaniu ryzyka** (*risk assessment*) a nie o pomiarze, chociaż obie grupy metod odwołują się do wydawałoby się wystarczająco precyzyjnych narzędzi jakimi są modelowanie zdarzeń i rachunek prawdopodobieństwa. Należy jednak zauważyć, że pojawienie się zdarzenia niekorzystnego zależy często od wielu rzadko występujących zdarzeń cząstkowych, dla których należy zbadać prawdopodobieństwa ich wystąpienia oraz pozyskać wiedzę na temat związków przyczynowo-skutkowych zachodzących między nimi. Powstaje jednak problem, skąd czerpać informacje o prawdopodobieństwach występowania zdarzeń cząstkowych?

Analiza ryzyka

Wykorzystuje się w tym celu następujące źródła informacji:

- Dane statystyczne gromadzone przez organizacje zajmujące się danymi zagadnieniami, które z góry należy uznać za niepełne i nie zawsze możliwe do zastosowania w danej instytucji.
- Oszacowania ekspertów, które z kolei mogą okazać się zbyt subiektywne.
- Oszacowania ekspertów skorygowane za pomocą np. metod iteracyjnego uzgadniania wartości prawdopodobieństw rzadko występujących zdarzeń, oszacowanych przez ekspertów na podstawie znajomości oszacowań innych ekspertów, co powoduje, że rozbieżność opinii maleje i wydają się być one bliższe rzeczywistości.

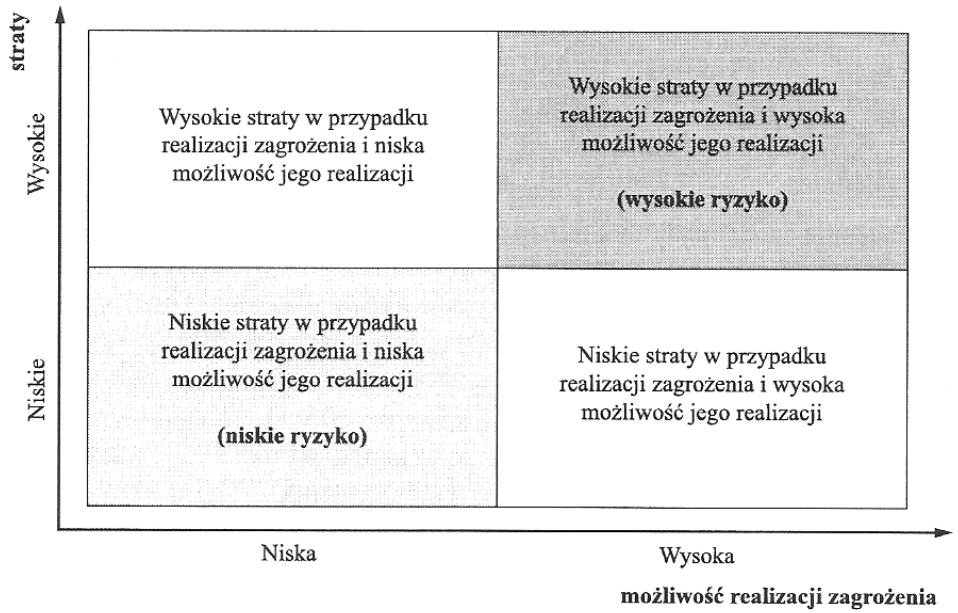
Drugim problemem jest zamodelowanie związków przyczynowo-skutkowych, jakie łączą zdarzenia cząstkowe. **Sposób modelowania stanowi istotę poszczególnych metod oceny ryzyka.** Przedstawione dalej metody oceny ryzyka podzielić można, na dwie grupy.

- Metody zstępujące, **od ogółu do szczegółu** (*top-down*), cechujące się **dedukcyjnym** badaniem przyczyn znanych skutków; takim skutkiem może być zdarzenie niepożądane w systemie, stąd też należy zbadać, jak do niego mogło dojść.
- Metody wstępujące, **od szczegółu do ogółu** (*bottom-up*), polegające na **indukcyjnym** wnioskowaniu o możliwych skutkach znanych przyczyn; przyczyną może być na przykład przełamanie zabezpieczeń systemu zaporowego - należy dociec do czego to może prowadzić i jakie skutki dla funkcjonowania instytucji może przynieść.

Analiza ryzyka

Pojęcie ryzyka wiąże możliwość (prawdopodobieństwo, częstość) wystąpienia zdarzenia z wielkością strat, które może ono powodować (konsekwencją zdarzenia). Potrzebna jest w tym wypadku ogólna ocena sytuacji i możliwość porównywania zjawisk rzadkich, ale dotkliwych, z częstymi, ale mniej groźnymi w skutkach. Ocena sytuacji pozwala wyznaczyć obszar ryzyka istotnego, podlegającego redukcji.

Wygodnym narzędziem służącym do tego celu jest **diagram częstości i konsekwencji *(frequency-consequences diagram)***, określany także jako mapa ryzyka [1-3]. Ma on postać tabeli lub wykresu. Podstawowa postać wykresu to czteropolowa mapa ryzyka wraz z interpretacją poszczególnych pól. Pola na takim wykresie nie muszą być równe.

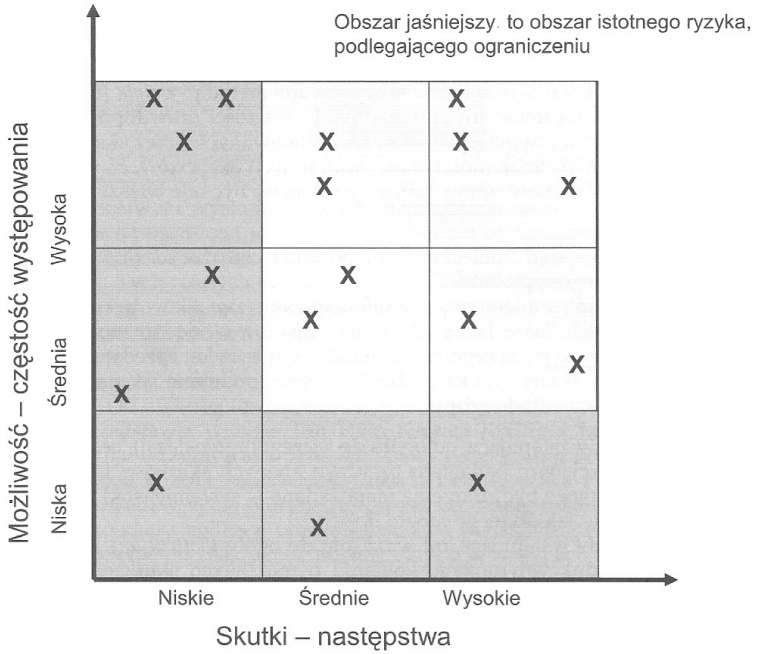


Analiza ryzyka

Inna możliwość to np. trójpoziomowa, jakościowa skala oceny. Symbole X oznaczają zidentyfikowane przypadki ryzyka. Otrzymujemy w ten sposób diagram częstości i skutków, podobny do poprzedniego ale z większą liczbą pól. W zależności od charakteru wielkości prezentowanych przez skalę, najczęściej spotyka się następujące przypadki [1]:

- Skale wyrażają zbiory predefiniowanych wartości umownych, na przykład mały, średni, duży - jest to przypadek analizy jakościowej.
- Skala częstości wyrażona ilościowo, na przykład liczba zdarzeń/rok, oraz skala konsekwencji wyrażona również ilościowo - najczęściej w walucie - jest to przypadek analizy ilościowej.

Stosowane są skale liniowe albo logarytmiczne.



Analiza ryzyka – metody jakościowe

Istnieje bardzo wiele metod **jakościowych** szacowania ryzyka. Metody przykładowe to [1]:

- **Metoda wstępnej analizy ryzyka/hazardu PRA/PHA** *(Preliminary Risk/Hazard Analysis)* polega na rygorystycznej ocenie sekwencji zdarzeń oraz czynników sprawczych, wyrażających związki między potencjalnym **ryzykiem wystąpienia incydentu, a samym incydentem.** Daje to odpowiedź na pytanie, jakie zdarzenia muszą zajść, by potencjalnie występujące **niebezpieczeństwo (hazard)**, przerodził się w niekorzystne zdarzenie. Wymaga to uprzedniej identyfikacji niekorzystnych zdarzeń cząstkowych i przeprowadzenia dokładnej analizy wpływu każdego z nich na wystąpienie incydentu.
- **Metoda HAZOP** (*Hazard and Operability studies*) powstała w Wielkiej Brytanii na początku lat siedemdziesiątych. Pierwotnie służyła do oceny zagrożeń w przemyśle chemicznym, jednak z czasem znalazła także zastosowanie w innych dziedzinach, **w tym w teleinformatyce**. Podstawą jest wypracowanie modelu analizowanego systemu. W tym celu są stosowane różne metody opisu formalnego, jak na przykład diagramy przepływu danych i sterowania, grafy przejść między stanami lub encje (*entities*). Modele mają budowę hierarchiczną (od ogółu do szczegółu), stąd analizy prowadzone przez zespół dobranych analityków mogą uwzględniać różny poziom szczegółowości. W toku ukierunkowanej dyskusji w zespole są identyfikowane możliwe odstępstwa, rozumiane tu jako hazardy. Analizowane są podatności elementów modelu oraz odnoszące się do nich zagrożenia.

Analiza ryzyka – metody jakościowe

- **Metody analizy defektów** FMEA *(Failure Mode and Effects Analysis)* oraz FMECA *(Failure Mode and Effects Criticality Analysis*) wzięły swój początek z prac, prowadzonych jeszcze w latach pięćdziesiątych XX w. nad **analizą niezawodnościową uzbrojenia i do tej pory są często stosowane w przemyśle lotniczym, kosmicznym i elektronicznym.** Istotą FMEA/FMECA jest analiza wpływu każdego potencjalnego defektu na funkcjonowanie całości systemu oraz uszeregowanie potencjalnych defektów według stopnia ich dotkliwości. Metoda FMECA stanowi rozszerzenie FMEA, gdyż **dodatkowo uwzględnia analizę stopnia dotkliwości defektu**. Bada się, czy dany defekt ma charakter krytyczny dla systemu w konkretnej sytuacji, to znaczy czy ma najwyższą możliwą dotkliwość, czyli grozi najpoważniejszymi możliwymi konsekwencjami. *Na przykład w lotnictwie za funkcje krytyczne uznaje się te, dla których wystąpienie jakiegokolwiek defektu uniemożliwia kontynuowanie bezpiecznego lotu lub lądowanie maszyny*.
- I wiele innych…

Analiza ryzyka – metody jakościowe

Przykład szacowania ryzyka wg. PN-ISO/IEC-27005 [2, 3]

Założenia:

1. Wartości zasobów zostały ocenione w skali liczbowej od 0 do 4.
2. Zostały wypełnione ankiety, w których każdemu rodzaju wcześniej zidentyfikowanego zagrożenia i każdej grupie zasobów, których dotyczy zagrożenie:
   - przypisano miarę poziomu zagrożenia w skali **(niski, średni, wysoki);**
   - przypisano miarę poziomu podatności zasobu w skali **(niski, średni, wysoki).**
3. Przyjęto arbitralnie punktową skalę miary ryzyka w postaci liczb całkowitych z przedziału 0-8.

Tabela Szacowanie ryzyka

	Poziom zagrożenia	**Niski**			**Średni**			**Wysoki**		
	Poziom podatności	**N**	**Ś**	**W**	**N**	**Ś**	**W**	**N**	**Ś**	**W**
Wartość zasobu	**0**	**0**	**1**	**2**	**1**	**2**	**3**	**2**	**3**	**4**
	1	**1**	**2**	**3**	**2**	**3**	**4**	**3**	**4**	**5**
	2	**2**	**3**	**4**	**3**	**4**	**5**	**4**	**5**	**6**
	3	**3**	**4**	**5**	**4**	**5**	**6**	**5**	**6**	**7**
	4	**4**	**5**	**6**	**5**	**6**	**7**	**6**	**7**	**8**

Analiza ryzyka – metody jakościowe

Przykład szacowania ryzyka wg. PN-ISO/IEC-27005 [2, 3] (c.d.)

Dla każdego zasobu rozważa się związaną z nim podatność i odpowiadające jej zagrożenie. **Jeśli podatności nie przyporządkowano zagrożenia lub zagrożeniu podatności, oznacza to, że obecnie nie występuje ryzyko (ale należy pamiętać, że w przyszłości to może się zmienić**). Każdemu wierszowi w tabeli odpowiada jakaś wartość zasobu i każdej kolumnie przyporządkowany jest jakiś poziom zagrożenia i podatności. Na przykład, jeśli zasób ma wartość **3,** zagrożenie jest **wysokie,** a podatność **niska,** miara ryzyka równa się **5.** Zakładając, że wartość zasobu równa się **2,** poziom zagrożenia jest **niski,** a poziom podatności **wysoki,** to miara ryzyka równa się **4..** Rozmiar tabeli - liczba kategorii zagrożenia, podatności i wartości zasobów - może być dostosowany do potrzeb konkretnej firmy. Zaletą przedstawionego sposobu postępowania jest możliwość porównania ryzyka.

Analiza ryzyka powinna dać też odpowiedź na pytanie, jakie zagrożenie jest najniebezpieczniejsze w sensie poziomu i wagi niekorzystnych dla firmy skutków takiego zdarzenia (dla uproszczenia mierzonych zwykle wartością zasobów, których dotyczy). Taki ranking zagrożeń może być potrzebny np. w celu redukcji zbioru możliwych zagrożeń (skrócenia procesu analizy ryzyka).

Analiza ryzyka – metody jakościowe

Przykład szacowania ryzyka wg. PN-ISO/IEC-27005 [2, 3] (c.d.)

W przykładzie użyto tabeli do połączenia punktowych miar skutków (mierzonych wartością zasobów, w skali od 1 do 5) i punktowych miar możliwości wystąpienia zagrożenia (poziomu - w skali od 1 do 5, uwzględniających podatności). Miarę ryzyka uzyskuje się, mnożąc odpowiednie komórki kolumn (b) i (c). W tym przykładzie 1 oznacza najmniejsze skutki i najmniejszą możliwość wystąpienia zagrożenia

Tabela. Ranking zagrożeń

Zagrożenie (a)	**Skutki wystąpienia zagrożenia** (wartość zasobu) (b)	**Poziom zagrożenia (c)**	**Miara ryzyka (d)**	**Ranking zagrożeń (e)**
Zagrożenie **A**	**5**	**2**	**10**	**2**
Zagrożenie B	**2**	**4**	**8**	**3**
Zagrożenie C	**3**	**5**	**15**	**1**
Zagrożenie **D**	**1**	**3**	**3**	**5**
Zagrożenie E	**4**	**1**	**4**	**4**
Zagrożenie F	**2**	**4**	**8**	**3**

Analiza ryzyka – metody jakościowe

Podczas planowania budowy systemu bezpieczeństwa, jeśli ma być zabezpieczanych kilka systemów teleinformatycznych, może zachodzić potrzeba określenia harmonogramu prac w zależności od wartości zasobów, poziomu zagrożenia i możliwości realizacji takiego zagrożenia. Analiza może być prowadzona kolejno dla różnych zasobów składających się na dany system w celu uzyskania syntetycznego wskaźnika „priorytetu" systemu. W tym celu wprowadza się kolejny parametr analizy ryzyka, odzwierciedlający możliwość realizacji zagrożenia, **zależny od poziomu zagrożenia i łatwości wykorzystania określonej podatności.** Na potrzeby przedstawionej analizy parametr ten nazwiemy **szacowaną możliwością realizacji** (dalej w skrócie **SMR**) i będą mu przypisywane wartości całkowite z zakresu 0-4 [3]. Parametr **SMR** ocenia się na podstawie poziomu zagrożenia i poziomu podatności.

Tabela Poziomy zagrożenia i podatności a szacunkowa możliwość realizacji zagrożenia

Poziomy zagrożenia	**Niski**			**Średni**			**Wysoki**		
Poziomy podatności	**N**	**Ś**	**W**	**N**	**Ś**	**W**	**N**	**Ś**	**W**
SMR	**0**	**1**	**2**	**1**	**2**	**3**	**2**	**3**	**4**

Analiza ryzyka – metody jakościowe

Parametr **SMR** nie uwzględnia ani wartości zasobu, ani tym samym motywacji potencjalnego intruza (którego siła ataku na system w celu zdobycia określonego zasobu informacyjnego będzie determinowana atrakcyjnością tego zasobu). Aby to uwzględnić, określa się, tak jak w tabeli poprzedniej, **wskaźnik wartość zasobu/zagrożenie** poprzez odszukanie przecięcia **wartości zasobu i SMR**. Wskaźnik ten może służyć do rozróżniania zasobów tworzących część systemu.

Tabela Ryzyko jako funkcja wartości zasobu i możliwości realizacji zagrożenia

Wartość zasobu	0	1	2	3	4
SMR					
0	0	1	2	3	4
1	1	2	3	4	5
2	2	3	4	5	6
3	3	4	5	6	7
4	4	5	6	7	8

Analiza ryzyka – metody jakościowe

Ostatnim etapem **kompleksowej** (tzn. obejmującej więcej niż jeden system teleinformatyczny) analizy ryzyka w wariancie jakościowym jest zsumowanie wszystkich wyników dla zasobów składających się na system i uzyskanie wskaźnika „priorytetu" dla systemu. Postępowanie to służy do zróżnicowania systemów i ustalenia priorytetów (który najpierw, a który może poczekać) ich zabezpieczania.

Niech A i N oznaczają ryzyko akceptowalne i nieakceptowalne. Tabela z poprzedniego slajdu może być zmieniona następująco:

Tabela. Akceptacja ryzyka szczątkowego

Wartość zasobu	0	1	2	3	4
SMR					
0	A	A	A	A	N
1	A	A	A	N	N
2	A	A	N	N	N
3	A	N	N	N	N
4	N	N	N	N	N

Wyznaczenie granicy między ryzykiem akceptowalnym i nieakceptowalnym (tutaj granica leży między 3 i 4), należy do kierownictwa firmy **i jest to decyzja arbitralna**, która powinna być jednak podbudowana wynikami procesu analizy ryzyka.

Analiza ryzyka – metody ilościowe

Analiza ryzyka dotyczy zwykle zdarzeń, których częstość występowania nie jest określona ani bezpośrednio wyznaczalna na odpowiednim poziomie ufności (najczęściej są to tzw. zdarzenia rzadkie). Z tego powodu w ocenie ryzyka używa się metod modelowania przystosowanych do szacowania małych prawdopodobieństw - **drzew błędów i drzew zdarzeń.** Metody są wykorzystywane **zarówno do analizy jakościowej, jak i ilościowej**. Po przeprowadzeniu analizy jakościowej (tj. bez oszacowania prawdopodobieństw), pomagają one zorientować się w całym zakresie ryzyka i zrozumieć sytuację, której ryzyko dotyczy. *Po przeprowadzeniu analizy ilościowej drzewa błędów i drzewa zdarzeń pomagają wyznaczyć prawdopodobieństwa pewnych zdarzeń lub ich ciągów*. W każdej z tych metod modelowania **zdarzenie złożone rozkłada się na mniejsze (prostsze) części,** które po starannej analizie łączy się ponownie, uzyskując lepsze zrozumienie całego zdarzenia oraz możliwość określenia występujących w nim prawdopodobieństw zdarzeń składowych (poprzez wyznaczanie prawdopodobieństw cząstkowych - niezbędne jest w tym celu dysponowanie prawdopodobieństwami zdarzeń elementarnych, tj. takich, które nie są już dalej rozkładane). Znaczącym problemem jest modelowanie zachowań ludzkich w tych procesach, których to zachowań nie można pominąć, a które generują mnóstwo zależności wzajemnych w modelach. Są one przedmiotem dociekań *Human Cognitive Reliability* (*HRA)* - dyscypliny, która zajmuje się modelowaniem ludzkich zachowań, zwłaszcza wyznaczaniem prawdopodobieństwa zachowań błędnych, reagowaniem na nie, a także błędami na styku człowieka z techniką [1].

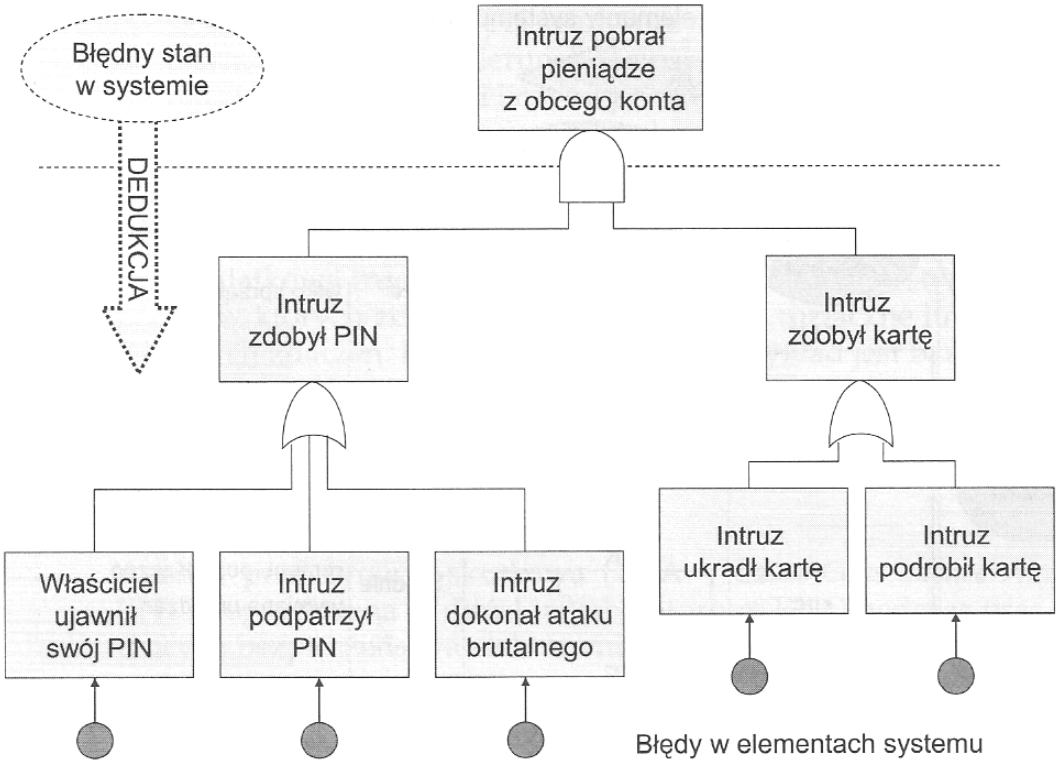
Analiza ryzyka – metody ilościowe

Metoda drzewa błędów

Metodę drzewa błędów (FTA - *Fault Tree Analysis)* opracowano w Bell Telephone Laboratories w latach sześćdziesiątych, podczas prac nad międzykontynentalnymi pociskami balistycznymi. Metoda FTA **ma charakter dedukcyjny**, to znaczy na podstawie skutków zdarzeń wnioskuje się o ich przyczynach. **Drzewo błędów jest diagramem logicznym**, który pokazuje zależność błędnego stanu w systemie od błędnych stanów komponentów, z których system jest zbudowany.

W systemie identyfikowany jest zbiór stanów błędnych, na przykład „włamano się do serwera", „pobrano z konta cudze pieniądze" lub „wybuchł pożar w archiwum nośników". Dla każdego z nich jest prowadzona analiza przyczyn - jak mogło dojść do wystąpienia danego stanu błędnego. Na rysunku pokazano **przykład drzewa błędów w aspekcie jakościowym.** W tym wypadku analityk skupił swoją uwagę na wykryciu przyczyn wystąpienia błędnego stanu w systemie („pobranie pieniędzy z cudzego konta"), a ściślej na określeniu wpływu błędnych stanów w komponentach systemu na wystąpienie błędnego stanu w całym systemie. Na rysunku jest pokazany kierunek prowadzenia analizy przez dedukcję**.** Analizowaliśmy w ten sposób zdarzenia, które musiały zajść, by wystąpił określony skutek.

Analiza ryzyka – metody ilościowe



Rys. 6. Metoda drzewa błędów – analiza jakościowa [2]

Analiza ryzyka – metody ilościowe

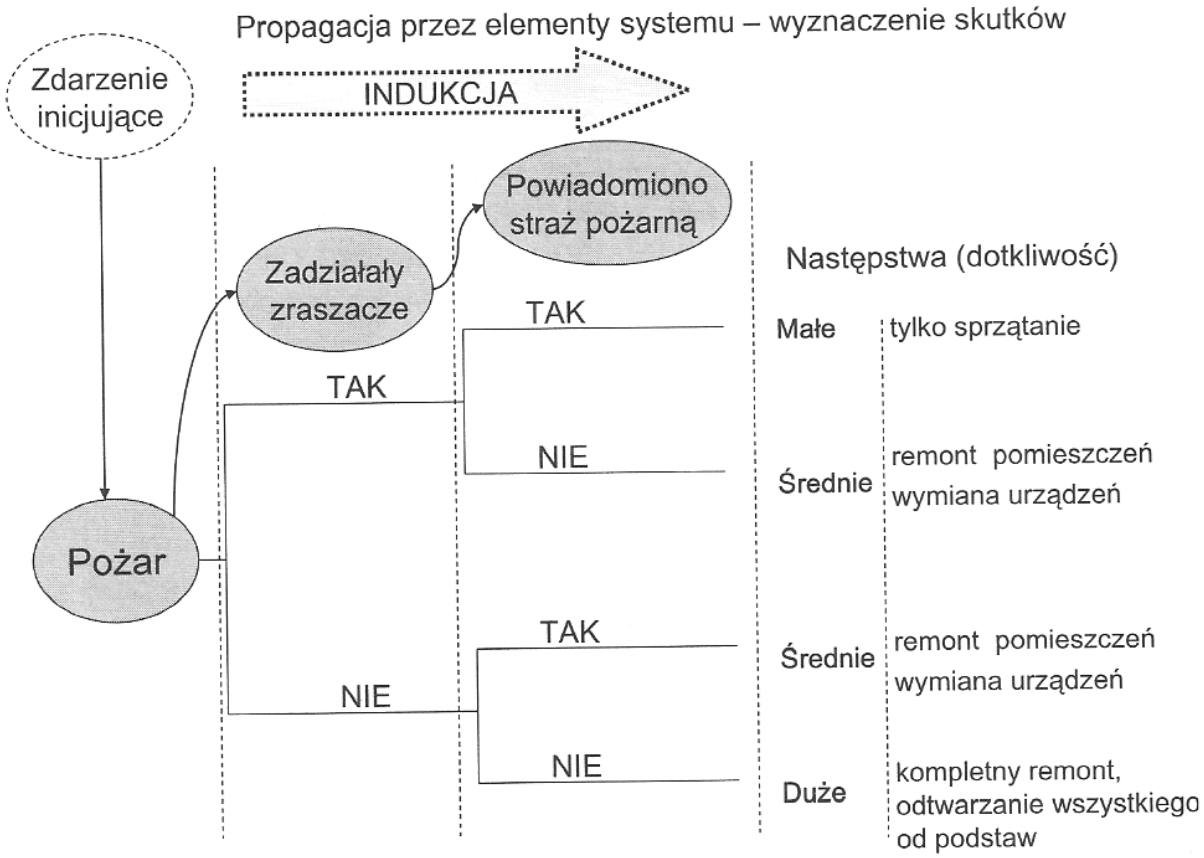
Metoda drzewa zdarzeń

Drzewo zdarzeń (ETA - *Event Tree Analysis)* jest **graficznym modelem zależności przyczynowo-skutkowych występujących w rozpatrywanym problemie**. Tworząc drzewo zdarzeń, zakłada się, że określony skutek jest wynikiem pewnego ciągu zdarzeń. Drzewo zdarzeń rozpoczyna się zatem pewnym zdarzeniem inicjującym i przedstawia wszystkie możliwe ciągi zdarzeń będące jego następstwami. W różnych miejscach drzewa zdarzeń znajdują się punkty rozgałęzień ilustrujące fakt, że po pewnych zdarzeniach mogą wystąpić różne inne. Prawdopodobieństwo określonego skutku oblicza się, mnożąc przez siebie prawdopodobieństwa wszystkich zdarzeń składających się na ścieżkę w drzewie, po której dochodzimy do rozważanego skutku.

Metoda drzewa zdarzeń ma charakter **indukcyjny,** to znaczy na podstawie danego zdarzenia cząstkowego wnioskuje się o wszystkich możliwych jego skutkach, przy czym analizę zaczyna się od zdarzenia inicjującego *(initial event).* Na kolejnych dwóch rysunkach pokazano przykład, odpowiednio, jakościowej oraz ilościowej analizy skutków wystąpienia pożaru w budynku. Skutki zdarzenia inicjującego przechodzą przez kolejne węzły systemu - tutaj zabezpieczenia (zraszacze, straż pożarna), które mogą być przełamywane lub też nie, od czego w rezultacie zależy wielkość następstw.

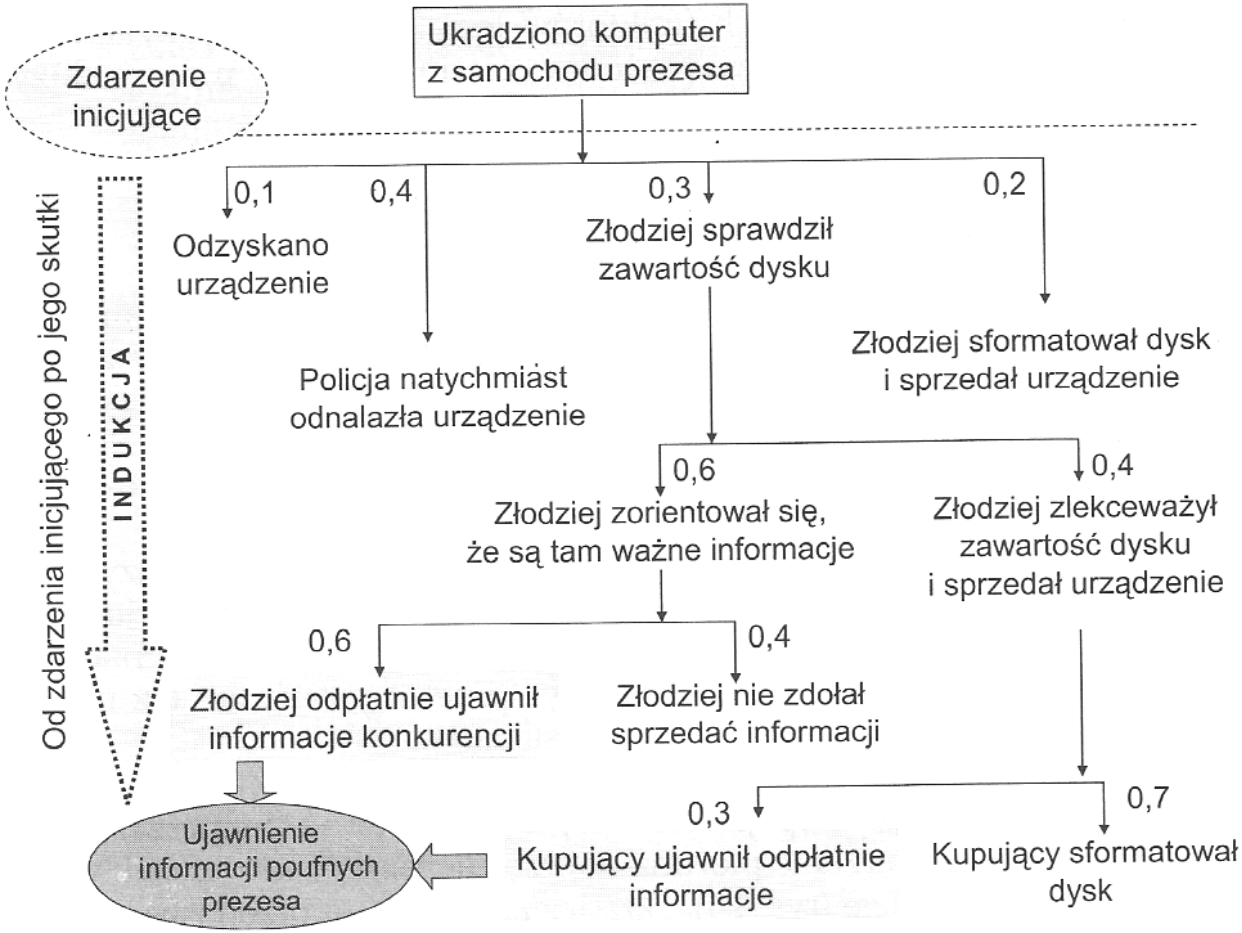
Zdarzeniami **inicjującymi** mogą być na przykład „zgubienie karty płatniczej", „pojawienie się obcej osoby w pomieszczeniach serwera", „uderzenie pioruna w linię zasilającą lub „kradzież komputera przenośnego użytkowanego przez prezesa firmy".

Analiza ryzyka – metody ilościowe



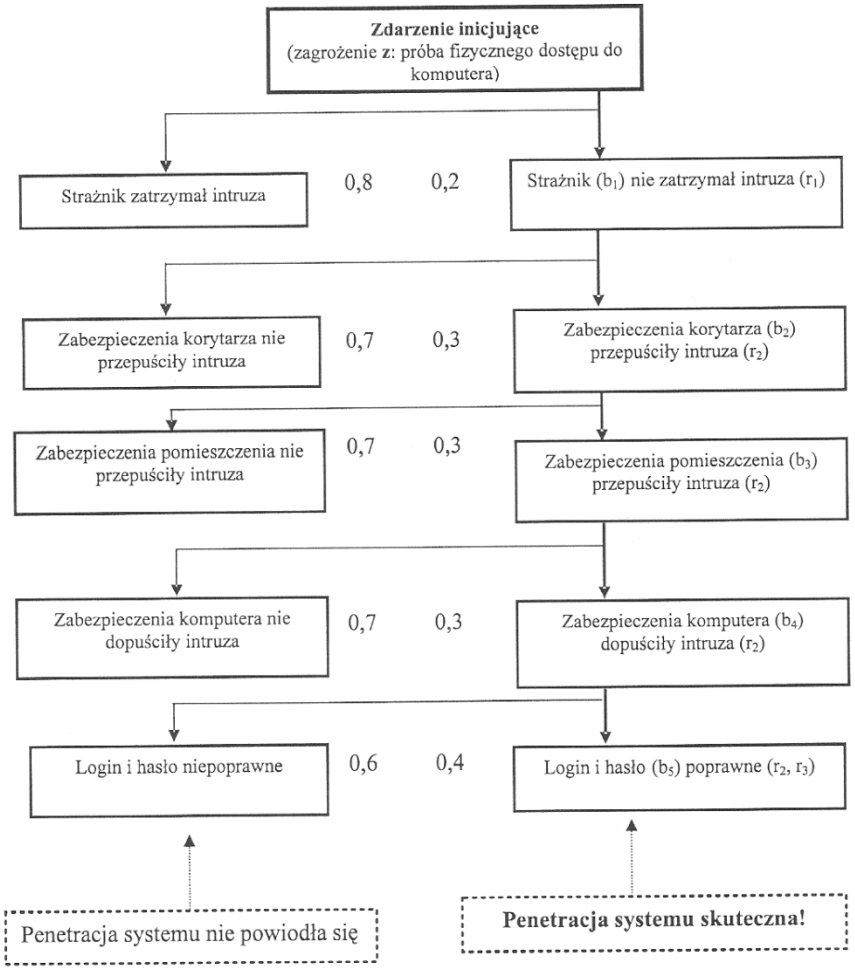
Rys. 7. Metoda drzewa zdarzeń – analiza jakościowa [1]

Analiza ryzyka – metody ilościowe



Rys. 8. Metoda drzewa zdarzeń – analiza ilościowa [1]

Analiza ryzyka – metody ilościowe



Rys. 9. Metoda drzewa zdarzeń – analiza ilościowa dla zdarzenia inicjującego „kradzież komputera przenośnego użytkowanego przez prezesa firmy” [2].

Analiza ryzyka – metody ilościowe

Na rysunku przedstawiono drzewo zdarzeń wraz z pogrubioną ścieżką penetracji, odpowiadającą próbie fizycznego dostania się nieupoważnionej osoby do wskazanego komputera i uruchomienia na nim sesji. Hipotetyczny system komputerowy jest chroniony następującymi zabezpieczeniami fizycznymi i programowymi $\{b_1, b_2, b_3, b_4, b_5\}$. **Interpretacja podatności** może być następująca [2, 3]:

- r_1 - niedbałe wykonywanie obowiązków przez strażnika (nie porównał osoby ze zdjęcia z osobą okazującą przepustkę);
- r_2 - źle wyszkoleni użytkownicy, np.:
  - użytkownik nie zgłosił kradzieży karty magnetycznej,
  - użytkownik zapisał PIN flamastrem na odwrocie karty,
  - używane było słabe hasło (nazwisko użytkownika).
- r_3 - brak okresowych kontroli siły haseł przez administratora ds. bezpieczeństwa.

Jeżeli prawdopodobieństwa zajścia poszczególnych zdarzeń są takie, jak na rysunku (liczby przy opisach czynności), to prawdopodobieństwo zrealizowania zagrożenia (nieupoważniona osoba dostała się do komputera i uruchomiła na nim sesję z uprawnieniami legalnego użytkownika) wynosi:

$$p=0,2*0,3*0,3*0,3*0,4=0,00216$$

Analiza ryzyka – metody ilościowe

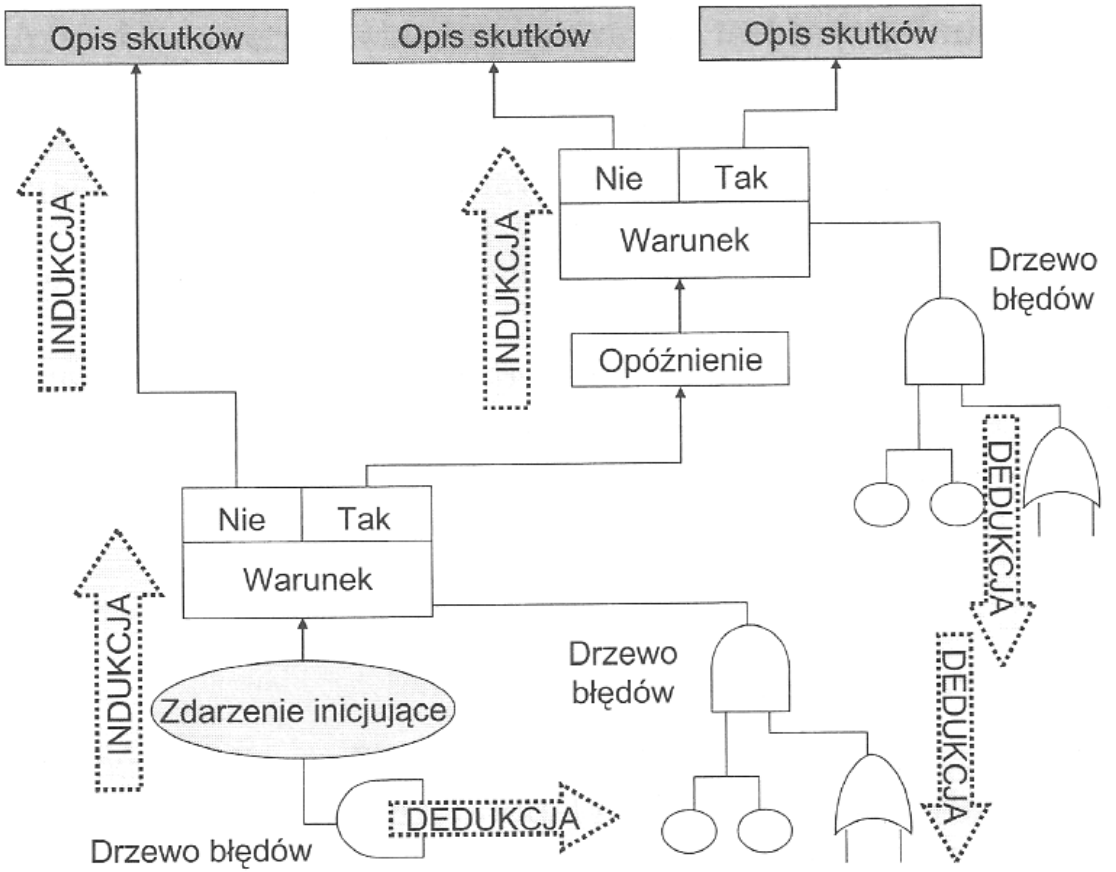
Połączeniem metody drzewa błedów i metody drzewa zdarzeń jest Analiza przyczynowo-skutkowa (CCA - *Cause-Consequence Analysis)*, opracowana w duńskim laboratorium RISO podczas prac dotyczących bezpieczeństwa elektrowni jądrowych, która łączy w sobie idee [1-3]:

- FTA - opartej na dedukcyjnym badaniu przyczyn wystąpienia błędnego stanu w systemie.
- ETA - analizującej w sposób indukcyjny skutki wystąpienia zdarzenia inicjującego.

Zadaniem CCA jest zidentyfikowanie łańcuchów zdarzeń prowadzących do niepożądanych skutków. Prawdopodobieństwo wystąpienia tych niepożądanych konsekwencji jest obliczane na podstawie prawdopodobieństw zdarzeń składających się na ich przyczyny.

Na kolejnym rysunku jest przedstawiony przykładowy diagram CCA. Analiza indukcyjna zaczyna się od zdarzenia inicjującego i kończy się na określeniu stanu błędnego oraz jego następstw (niepożądanych skutków). W sieci modelującej system pojawiły się węzły zawierające opóźnienia lub warunki, przy czym warunki są generowane w sposób dedukcyjny, na podstawie swoich lokalnych drzew błędów (jak mogło dojść do ich spełnienia?). Również zdarzenie inicjujące może być wyprowadzone z drzewa błędów.

Analiza ryzyka – metody ilościowe



Rys. 10. Metoda CCA – połączeniem metody drzewa błędów i metody drzewa zdarzeń [1]

Analiza ryzyka – metody ilościowe

Podstawowym założeniem i jednocześnie słabym punktem metodologii drzewa błędów i drzewa zdarzeń **jest przekonanie**, że jeżeli skutkowi nie można przypisać prawdopodobieństwa w sposób natychmiastowy i bezpośredni, to skutek ten da się rozłożyć na ciągi zdarzeń prowadzących do niego i znajdą się zdarzenia takie (nazywane elementarnymi), których prawdopodobieństwa są znane na podstawie doświadczenia lub które można uzyskać od ekspertów z danej dziedziny.

Analiza ryzyka – podsumowanie

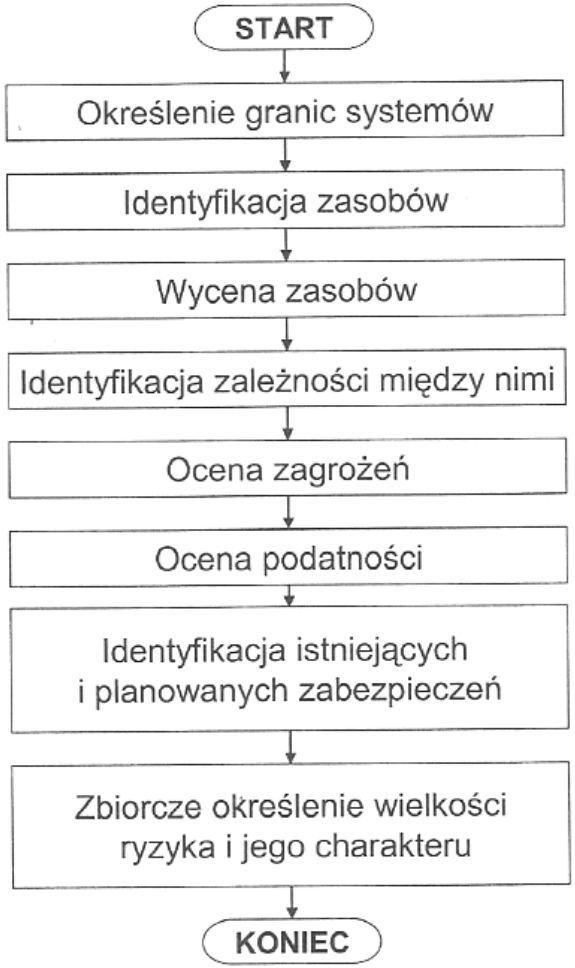
Rozróżnia się następujące rodzaje analizy ryzyka:

- Wysokopoziomową (o wysokim poziomie ogólności) analizę ryzyka, prowadzoną w sposób ogólny i zgrubny.
- Nieformalną analizę ryzyka, prowadzoną w sposób dość szczegółowy, ale bez użycia specjalistycznych metod i narzędzi oceny, zwykle przez pewne gremium fachowe odpowiedzialne za bezpieczeństwo teleinformatyczne w instytucji.
- Formalną szczegółową analizę ryzyka, wspartą zaawansowanymi komputerowymi narzędziami jego oceny, którymi dysponują tylko nieliczne firmy konsultingowe, stąd zwykle jest konieczny udział specjalistów z tych firm w procesie oceny ryzyka.

Niezależnie od stopnia szczegółowości i sformalizowania analiza ryzyka przebiega zawsze według podobnego schematu. Różne mogą być jedynie stopień szczegółowości oraz sam sposób opisu poszczególnych elementów bezpieczeństwa, takich jak zasób, zagrożenie, podatność, zabezpieczenie czy samo ryzyko.

Każda metoda analizy ryzyka musi umożliwiać wyrażanie w jednolity sposób jego wielkości, jakościowo lub ilościowo, niezależnie od charakteru ryzyka. **Należy podkreślić, że ryzyko może mieć bardzo różne podłoże, związane przede wszystkim z charakterem następstw**. Są bowiem następstwa, które można wyrazić w kwotach pieniężnych, jednak większość z nich może być szacowana jedynie za pomocą wartości umownych, związanych z różnymi kategoriami szkód. W jednym wypadku chodzi o utratę informacji wrażliwych bądź ciągłości działania, w innym o utratę dobrego wizerunku instytucji, a czasem nawet o utratę życia lub zdrowia ludzkiego.

Analiza ryzyka – podsumowanie



Rys. 11. Ogólny schemat prowadzenia analizy ryzyka [1]

Analiza ryzyka – podsumowanie

W celu zapewnienia porównywalności oceny następstw **wszystkie ryzyka muszą być wyrażane w jednolitej skali umownej**, gdzie elementarna jednostka dla konkretnej instytucji może mieć przypisaną ustaloną wartość. W niektórych rozwiązaniach analizatorów wszelkie szkody można wyrazić w postaci kwot (ilościowo), jednak powszechnie stosowane są skale umowne (ocena jakościowa), czasem nawet dość dokładne, na przykład od 1 do 100. **W tym sensie miara ryzyka staje się miarą poziomu bezpieczeństwa w instytucji.** Największym problemem jest ustalenie jednolitych zasad oceny zjawisk i własności o bardzo różnorodnym charakterze, a przy tym **odmiennych dla każdej instytucji.** Istnieją jednak efektywne metody kumulowania, inaczej agregacji ocen cząstkowych, które są implementowane we współczesnych analizatorach ryzyka i stosowane także do oszacowań ręcznych.

Zarządzanie ryzykiem

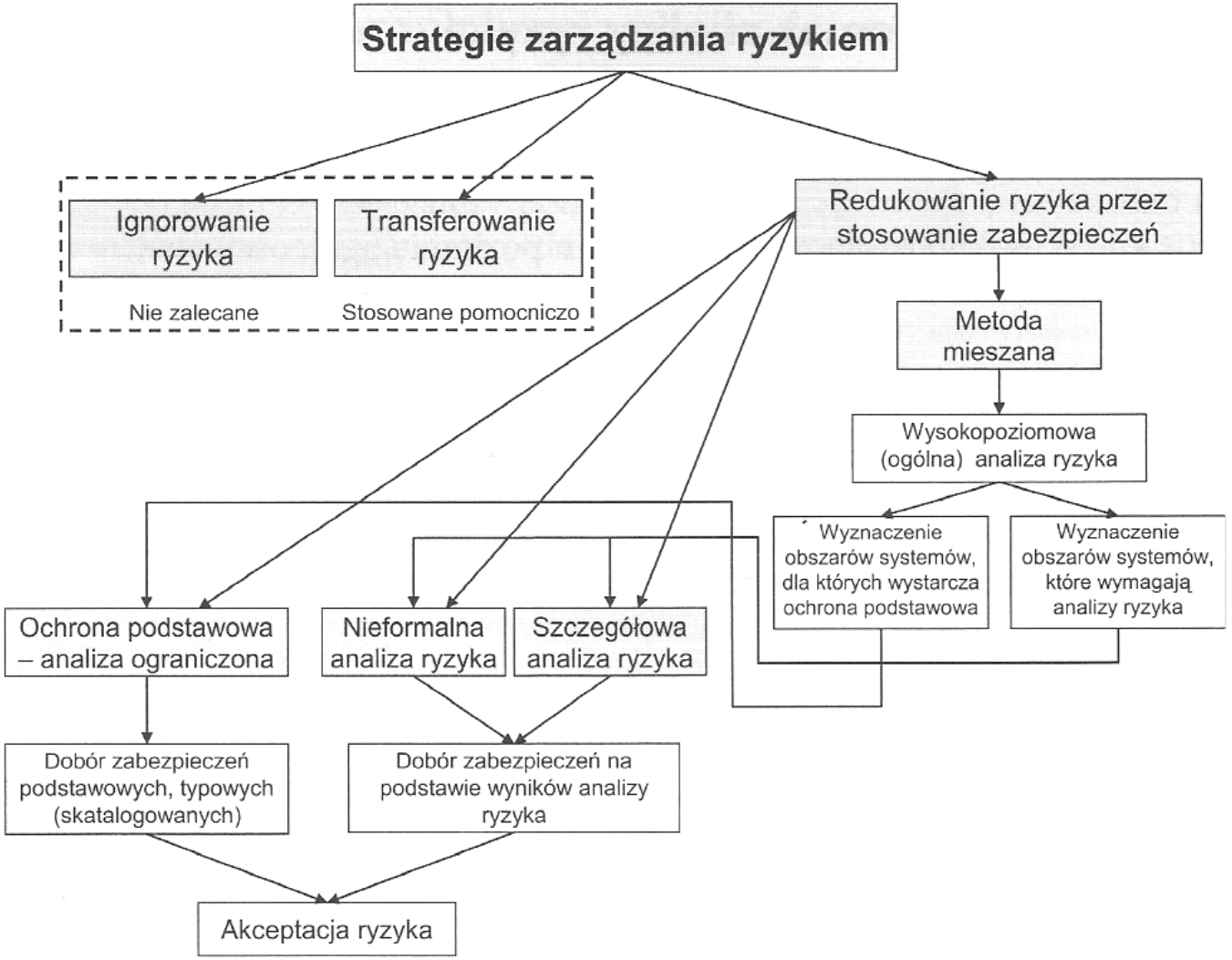
Z każdą parą „zagrożenie-podatność" jest związane ryzyko utraty bezpieczeństwa, z którym należy „coś" uczynić. To „coś" to właśnie czynności składające się na **proces zarządzania ryzykiem**. Ocena ryzyka jest częścią szerszego procesu – **zarządzania bezpieczeństwem informacji w organizacji**.

Proces zarządzania ryzykiem przebiega zawsze zgodnie z przyjętą dla instytucji strategią zarządzania ryzykiem. Istnieją w tym względzie następujące strategie:

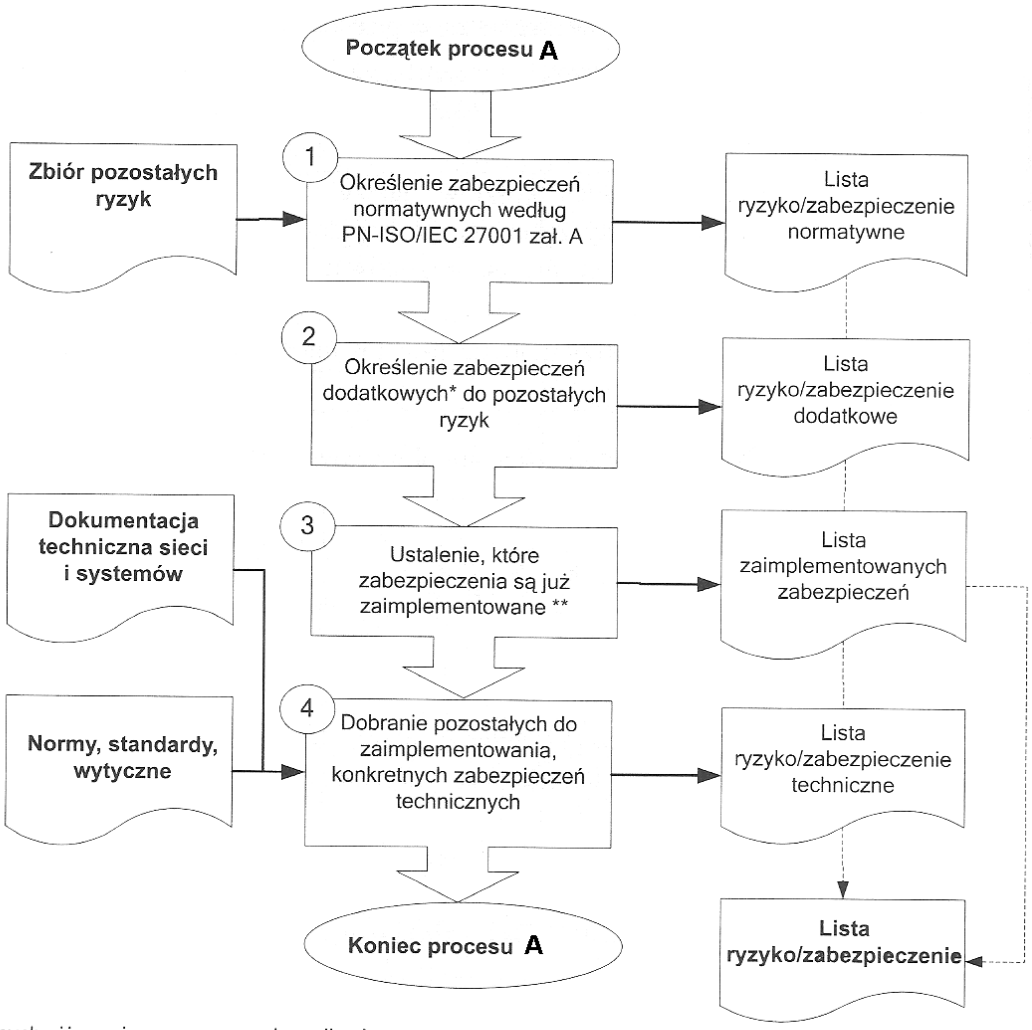
- **Ignorowanie istnienia ryzyka** - podmioty odpowiedzialne i świadome swoich działań nie powinny się decydować na taką strategię, choć nadal wiele zarządów instytucji tak właśnie postępuje.
- **Transferowanie ryzyka (ubezpieczenie się od ryzyka)** - po wniesieniu stosownej opłaty, przeniesienie ryzyka na instytucję ubezpieczającą. Jednak bez pewnych obwarowań (w praktyce zabezpieczeń redukujących ryzyko) uczynić tego nie można. Tą strategię należy uznać raczej za „uzupełniającą".

Zarządzanie ryzykiem

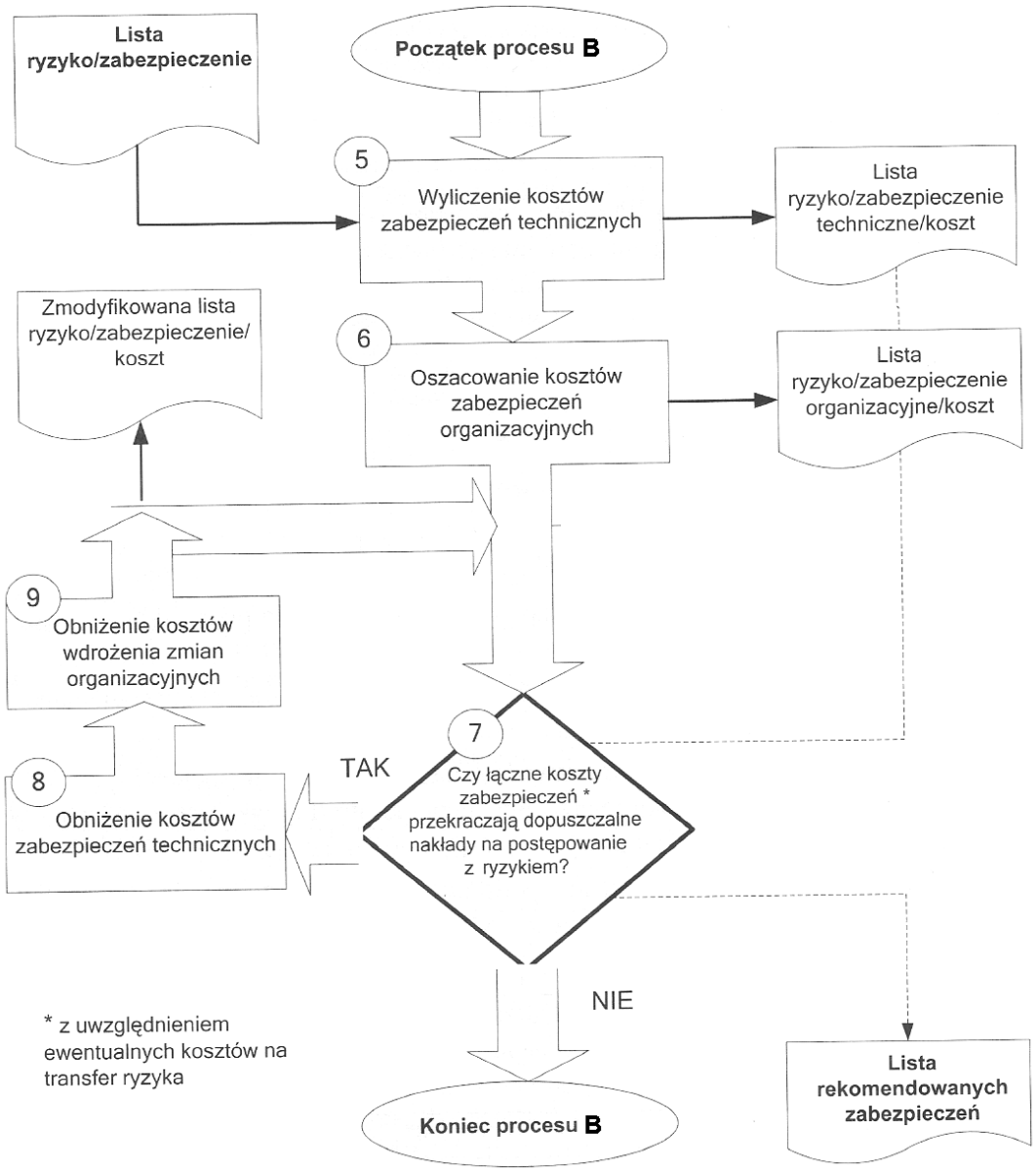
- **Redukcja ryzyka** przez stosowanie zabezpieczeń. Wymaga ona **najpierw oszacowania wielkości tego ryzyka**. Istnieją cztery podstawowe strategie redukcji ryzyka, różniące się sposobem jego analizy [1, 3]:
  - **zastosowanie zabezpieczeń typowych** dla określonych warunków, często nawet skatalogowanych, czyli **ochrona podstawowa** (*baseline approach*); całość systemów jest traktowana w ten sam sposób, niezależnie od rzeczywistego ryzyka, którego właściwie się nie bada, co prowadzi zwykle albo do niedoszacowania ryzyka, albo do przeszacowania nakładów na zabezpieczenia;
  - **przyjęcie zabezpieczeń po przeprowadzeniu nieformalnej,** często **uproszczonej analizy ryzyka** (*informal approach)* - analiza koncentruje się na tych obszarach, które wydają się być najbardziej narażone;
  - **przyjęcie zabezpieczeń wynikających ze szczegółowej, zwykle formalnej analizy ryzyka** (*detailed risk analysis)* - całość systemów jest poddana dokładnej analizie ryzyka, często wspomaganej narzędziami programowymi;
  - **metoda mieszana** (łączona, kombinowana) - w wyniku ogólnej (prowadzonej na wysokim poziomie ogólności) analizy ryzyka (HLRA - *High Level Risk Analysis)* wyznacza się obszary systemu szczególnie narażone lub posiadające fundamentalne znaczenie dla funkcjonowania instytucji, dla których zabezpieczenia dobiera się na podstawie analizy ryzyka, zaś dla reszty systemów stosowana jest ochrona podstawowa (*combined approach)*.



Rys. 12. Podstawowe strategie zarządzania ryzykiem [1]



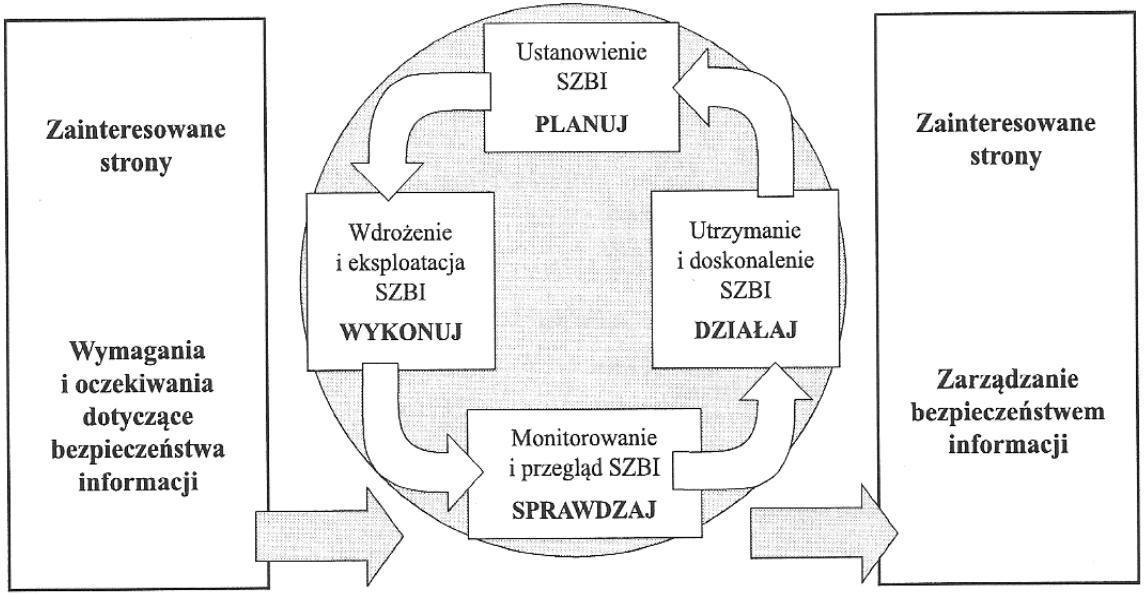
Rys. 13. Redukcja ryzyka – dobranie zabezpieczeń (Proces A) [2]



Rys. 14. Redukcja ryzyka – analiza kosztów/korzyści (Proces B) [2]

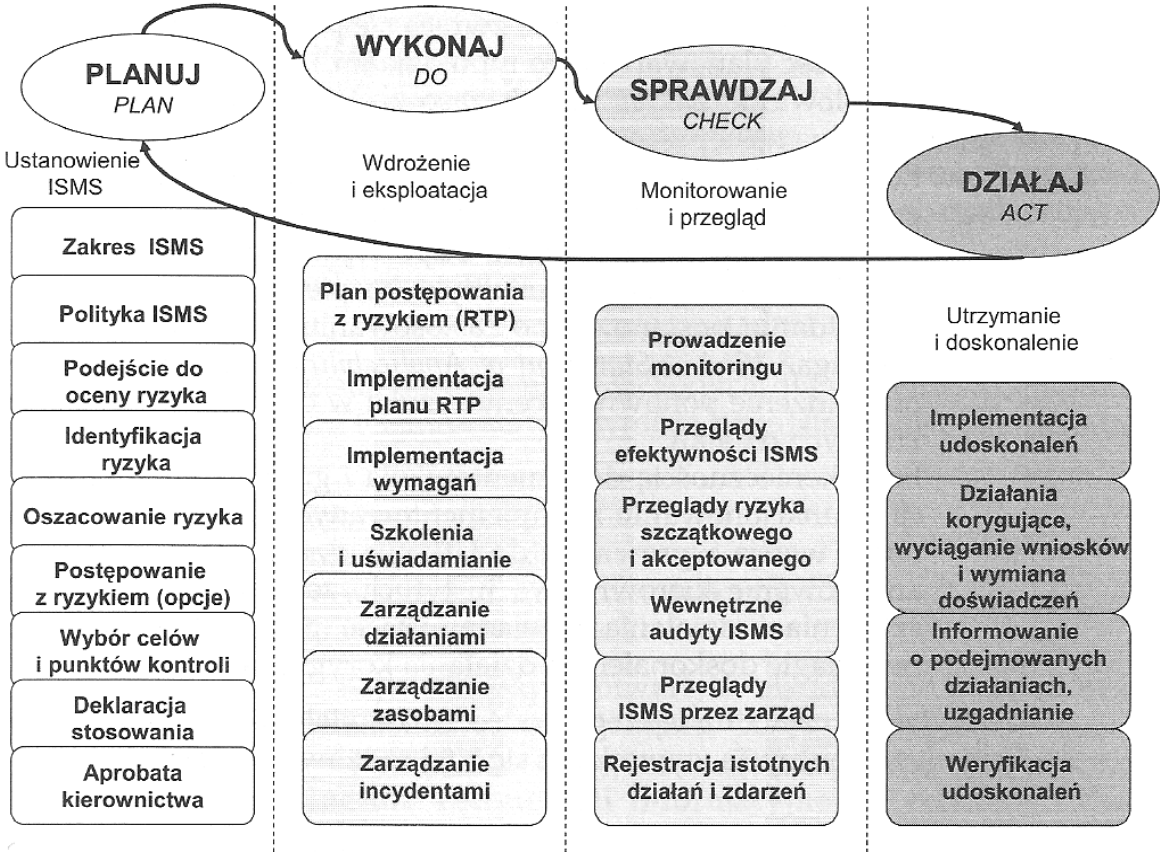
Zarządzanie bezpieczeństwem systemów teleinformatycznych

Punktem wyjścia dla zarządzania bezpieczeństwem jest **ogólny schemat zarządzania bezpieczeństwem informacji** w instytucji wprowadzony normą **BS 7799-2:2002 i dalej normami** ISO/IEC 27001 oraz PN-ISO/IEC 27001. Norma przedstawia rozbudowany schemat zarządzania o nazwie: **PLANUJ - WYKONAJ - SPRAWDZAJ - DZIAŁAJ** (***PDCA: PLAN - DO - CHECK - ACT***).



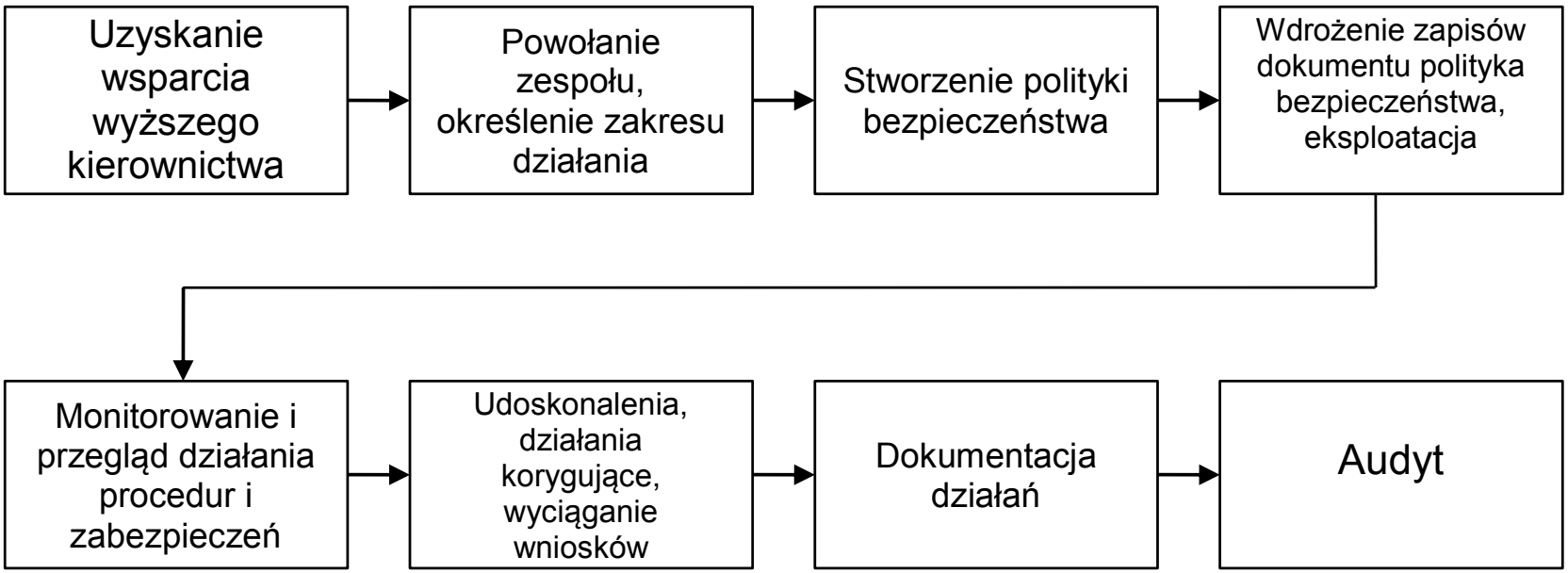
Rys. 15. Model PDCA działań w ramach SZBI [2, 3]

Zarządzanie bezpieczeństwem systemów teleinformatycznych



Rys. 16. Poszczególne działania w kolejnych fazach modelu PDCA. Cały proces zarządzania bezpieczeństwem powinien być wykonywany **cyklicznie, w miarę ciągle**.

Zarządzanie bezpieczeństwem systemów teleinformatycznych



Rys. 17. Proces tworzenia systemu zarządzania bezpieczeństwem informacji

Zarządzanie bezpieczeństwem systemów teleinformatycznych

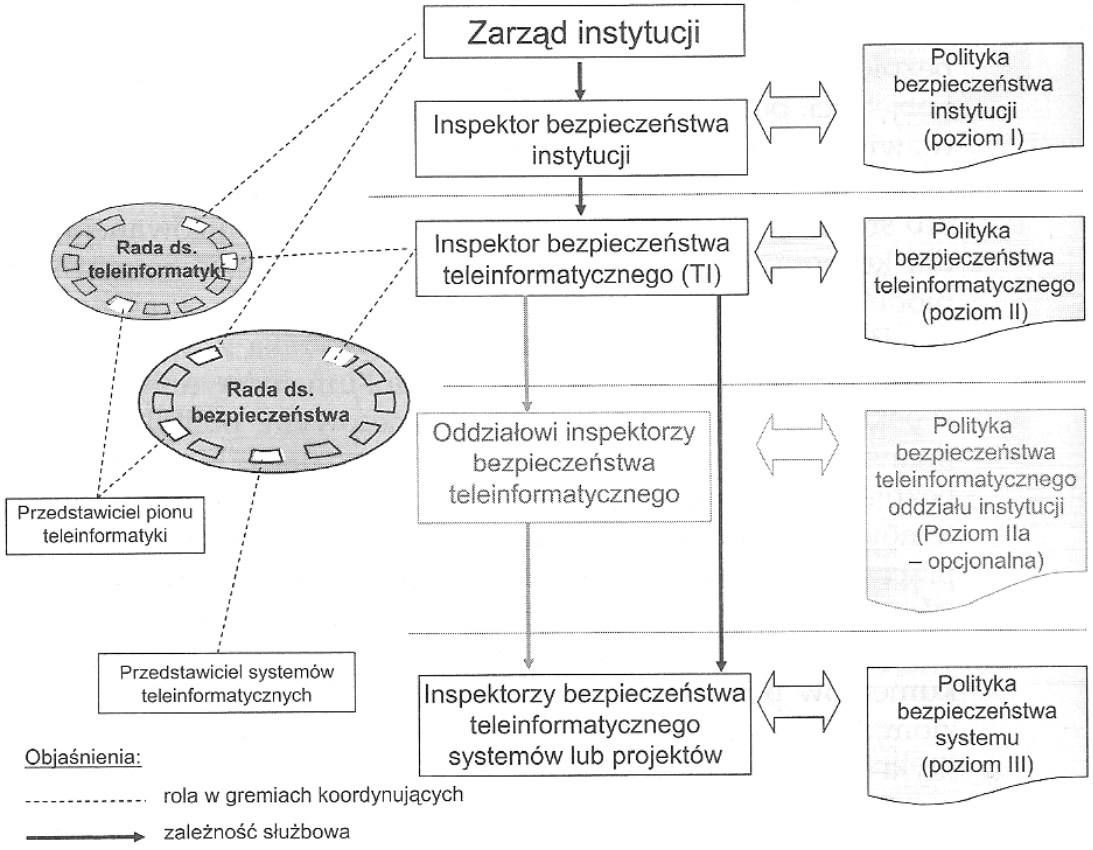
Punktem wyjścia dla implementacji zarządzania bezpieczeństwem jest **przyjęcie modelu PDCA**, a więc także zgoda na cykliczność działań w obszarze bezpieczeństwa oraz powołanie w instytucji zespołu/zespołów odpowiedzialnych za realizację i nadzorowanie związanych z tym procesów. **Zespoły powinny być zorganizowane, zgodnie z trójpoziomowym modelem odniesienia, w formie hierarchicznej struktury zarządzającej. Hierarchia ta wyraża schemat delegowania uprawnień za bezpieczeństwo instytucji na niższe szczeble jej organizacji.**

Liczność zespołów i złożoność struktury powinna odpowiadać potrzebom instytucji. Chociaż bezpieczeństwo ma charakter interdyscyplinarny, jednak przede wszystkim jest oparte na postawie i działaniach personelu, od którego wymaga się szczególnego zaangażowania. Z tego punktu widzenia określić należy:

- schemat zależności służbowych, tworzących strukturę zarządczą;
- role wyznaczające kompetencje i obowiązki uczestników procesów.

Istotne jest odpowiednie rozdzielenie obowiązków, co powinno zapewnić osiąganie podstawowych celów i sprawną realizację związanych z tym zadań.

Zarządzanie bezpieczeństwem systemów teleinformatycznych



Rys. 18. Przykład hierarchicznej organizacji służb odpowiedzialnych za bezpieczeństwo [1]

Zarządzanie bezpieczeństwem systemów teleinformatycznych

Dla każdej z organizacji pokazanych na rysunku są określane jej kompetencje i zadania. Przykładowe zadania dla **inspektora bezpieczeństwa teleinformatycznego** to:

- Realizacja polityki bezpieczeństwa instytucji w zakresie systemów teleinformatycznych.
- Nadzór nad wdrożeniem programu wynikającego z polityki bezpieczeństwa systemów teleinformatycznych.
- Koordynacja procesu zarządzania incydentami.
- Organizacja przedsięwzięć pogłębiania świadomości w zakresie bezpieczeństwa wśród personelu całej instytucji.
- Współpraca i przedkładanie raportów do rady ds. bezpieczeństwa teleinformatyki, inspektora bezpieczeństwa (albo dla zarządu).
- Definiowanie i egzekwowanie wymagań stawianych inspektorom bezpieczeństwa teleinformatycznego konkretnych systemów lub projektów oraz oddziałowym inspektorom bezpieczeństwa, jeśli w instytucji takowi funkcjonują.

Wymienione zadania odnoszą się do zarządzania bezpieczeństwem **na poziomie drugim** trójpoziomowego modelu odniesienia. Zakres kompetencji i obowiązków **oddziałowego inspektora** jest podobny do zakresu działania inspektora bezpieczeństwa teleinformatycznego przy czym ten zakres obejmuje wybrany oddział instytucji, posiadający swoją specyfikę.

Zarządzanie bezpieczeństwem systemów teleinformatycznych

Każdy wydzielony (autonomiczny) system albo realizowany projekt powinien mieć swojego inspektora odpowiedzialnego za bezpieczeństwo. Może to być oddzielne stanowisko lub wchodzić dodatkowo w zakres obowiązków związany z już istniejącym stanowiskiem. Osoba ta odpowiada przed inspektorem bezpieczeństwa teleinformatycznego albo przed właściwym oddziałowym inspektorem bezpieczeństwa teleinformatycznego, jeśli takiego powołano. Przykładowe Zadania **inspektora bezpieczeństwa systemu lub projektu** obejmują:

- Rozpowszechnianie i stałą aktualizację polityki bezpieczeństwa projektu lub systemu teleinformatycznego.
- Opracowywanie i wdrażanie planu zabezpieczeń.
- Stałe monitorowanie skuteczności zabezpieczeń systemów teleinformatycznych.
- Inicjowanie i pomoc w zarządzaniu incydentami, zwłaszcza w odpowiednim reagowaniu, ograniczaniu ich skutków, zbieraniu dowodów i prowadzeniu postępowań wyjaśniających.
- Współpraca i przedkładanie raportów radzie bezpieczeństwa teleinformatyki, inspektorowi bezpieczeństwa teleinformatycznego albo oddziałowemu inspektorowi bezpieczeństwa teleinformatycznego, jeśli takiego powołano.

Zarządzanie bezpieczeństwem systemów teleinformatycznych

Przez analogię do dokumentu polityki, również schemat organizacyjny służb odpowiedzialnych za bezpieczeństwo można uprościć. Dla skrajnie uproszczonego przypadku – firmy jednoosobowej korzystającej z komputera - jej właściciel jest sam dla siebie „głównym informatykiem" i również sam odpowiada za bezpieczeństwo teleinformatyczne swojej firmy. W miarę rozwoju firmy swoje obowiązki i kompetencje **deleguje na angażowanych w tym celu pracowników**, nadzorując jedynie ich poczynania, gdyż **z globalnej odpowiedzialności za całość bezpieczeństwa zarząd nigdy nie może być zwolniony**. Struktury stopniowo mogą się rozrastać aż do rozmiarów pokazanych na rysunku.

Audyt bezpieczeństwa teleinformatycznego

Słowo **audyt** jest definiowane na wiele sposobów. Za [2] przyjmiemy, że audytem nazywa się postępowanie sprawdzające sposób i/lub wynik wykonania czegoś (budowy systemu zabezpieczeń, zarządzania informatyką, wydatkowania funduszy itp.) pod względem zgodności z określonym wzorcem audytowym (wymaganiami lub standardami albo normami), wykonywane przez stronę niezależną. Niezależność, w przypadku systemów informacyjnych, musi być zachowana w stosunku do:

- zespołu projektującego lub budującego system informatyczny lub system zabezpieczeń,
- dostawców sprzętu i oprogramowania,
- organizacji podlegającej przeglądowi (w takim sensie, że w skład zespołu audytowego nie mogą wchodzić pracownicy organizacji zlecającej audyt).

Jeżeli nie jest dotrzymane któreś z tych wymagań, to zwykle mówi się o ***przeglądzie*** *wg listy audytowej* lub *przeglądzie bezpieczeństwa,* a nie o audycie.

Audyt bezpieczeństwa teleinformatycznego

Rozważając szczególny przypadek oceny, jakim jest audyt, można ze względu na jej obszar tematyczny wskazać następujące typy audytów (wg klasyfikacji IIA *(Institute of Internal Auditors* - Instytut Audytorów Wewnętrznych):

- ***finansowy*** - obejmuje analizę działalności organizacji w zakresie wyników finansowych i zagadnień księgowych; polega na niezależnej i obiektywnej weryfikacji i wyrażeniu opinii o prawidłowości i rzetelności sprawozdania finansowego (Audyt jest wykonywany przez biegłego rewidenta na podstawie *Ustawy o biegłych rewidentach* oraz zgodnie z *Normami wykonywania zawodu)*;
- ***zgodności*** - jest to analiza i ocena kontroli finansowych i operacyjnych oraz transakcji pod kątem ich zgodności z przepisami, planami, procedurami i standardami;
- ***operacyjny*** - obejmuje analizę i ocenę wszystkich lub wybranych funkcji organizacji (np. wsparcia informatycznego w podejmowaniu decyzji przez kierownictwo) pod kątem wydajności, ekonomiczności oraz efektywności, z jaką te funkcje są realizowane w celu osiągnięcia celów biznesowych organizacji.

Audyt bezpieczeństwa teleinformatycznego

Wariantem audytu operacyjnego jest audyt informatyczny, tj. audyt organizacji systemów informatycznych oraz projektów takich systemów wykorzystywanych w procesach biznesowych. **Cele wykonywania audytu informatycznego** to przede wszystkim [3]:

- weryfikacja zgodności działania systemów informatycznych z wymogami prawa (np. Ustawą o ochronie danych osobowych i Rozporządzeniem Rady Ministrów z dnia 12 kwietnia 2012 r. w sprawie **Krajowych Ram Interoperacyjności (KRI**), minimalnych wymagań dla rejestrów publicznych i wymiany informacji w postaci elektronicznej oraz minimalnych wymagań dla systemów **teleinformatycznych**);
- weryfikacja stanu bezpieczeństwa systemów informatycznych (w razie potrzeby także pojedynczych aplikacji) uwzględniająca skutki zidentyfikowanego ryzyka oraz zaimplementowane procedury kontrolne i ich efektywność;
- analiza ryzyka związanego z prowadzeniem projektu informatycznego.

Audyt bezpieczeństwa teleinformatycznego

Ponieważ część sprawdzeń wykonywanych w ramach audytu informatycznego dotyczy bezpieczeństwa systemów teleinformatycznych, przyjmujemy że audyt bezpieczeństwa teleinformatycznego jest podzbiorem sprawdzeń wykonywanych w ramach audytu informatycznego. Należy także zauważyć, że ze względu na koszty przedsięwzięcia i uzyskane wyniki, jest świadomość **różnic między audytem informatycznym a audytem bezpieczeństwa teleinformatycznego.** I tak w ramach audytu bezpieczeństwa teleinformatycznego nie ocenia się czynników ekonomicznych, na przykład tego, czy outsourcing usług informatycznych [3]:

- prowadzi do obniżenia kosztów informatyki,
- daje usługi lepszej jakości,
- daje dostęp do nowych technologii,
- daje dostęp do wiedzy i umiejętności specjalistów strony świadczącej usługi outsourcingowe,

natomiast sprawdza się, czy usługi outsourcingowe nie prowadzą do naruszenia poufności, integralności lub dostępności informacji, których właścicielem jest badana organizacja, tj. do pogorszenia poziomu bezpieczeństwa teleinformatycznego.

Audyt bezpieczeństwa teleinformatycznego

Podsumowując, można stwierdzić, że [3]:

- Audyt bezpieczeństwa teleinformatycznego może występować jako samodzielne przedsięwzięcie lub może być częścią audytu informatycznego.
- Audyt bezpieczeństwa teleinformatycznego wymaga specjalistycznej wiedzy, różnej od wiedzy wymaganej na przykład przy audycie finansowym.
- Audyt bezpieczeństwa teleinformatycznego nie dotyczy strony ekonomicznej stosowania środków informatyki w procesach biznesowych (mimo że procesy biznesowe są uwzględniane przy ocenie ryzyka i podatności systemu). Oceny takie są natomiast zwykle przeprowadzane w ramach audytów informatycznych i operacyjnych
- Audyt bezpieczeństwa teleinformatycznego nie dotyczy ryzyka związanego z prowadzeniem przez audytowaną organizację projektów z dziedziny informatyki ani oceny takich projektów. Oceny takie są natomiast zwykle przeprowadzane w ramach audytów informatycznych i operacyjnych.
- Audyt bezpieczeństwa teleinformatycznego nie zawiera szczegółowego badania aplikacji (w sensie badania kodu i spełnienia wymagań funkcjonalnych i operacyjnych - chyba że jest to wyraźnie zaznaczone w umowie). Badany jest natomiast stopień zaaplikowania łat i uaktualnień likwidujących znane podatności. Jeżeli organizacja prowadzi własne prace projektowe, to sprawdzeniu podlega także przestrzeganie pewnych reguł, na przykład bezpiecznego projektowania.

Audyt bezpieczeństwa teleinformatycznego

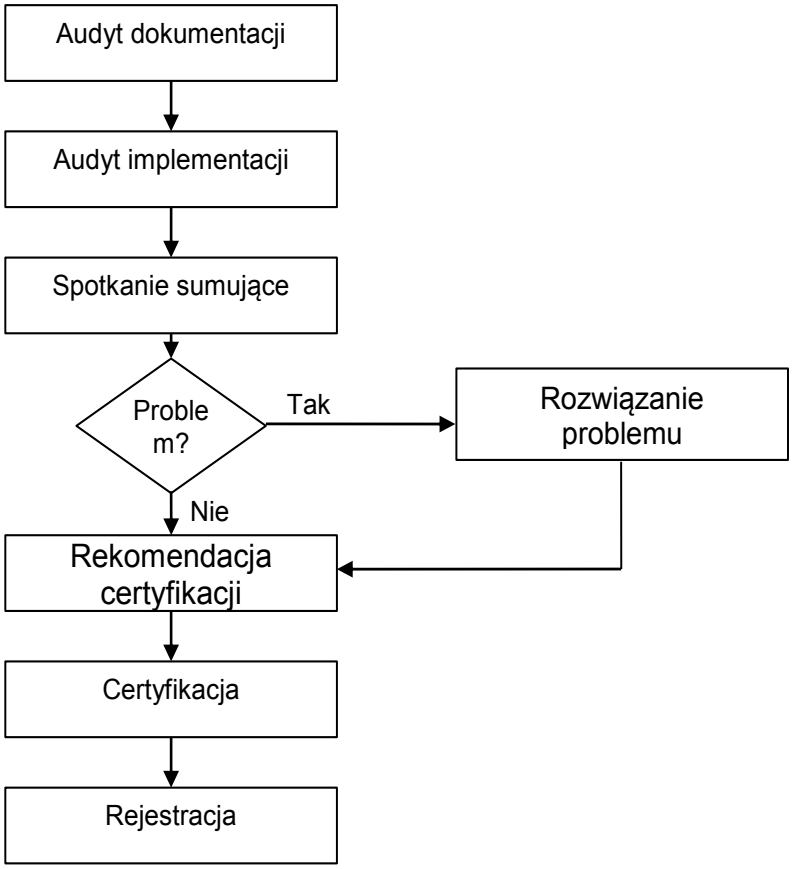
- Audyt bezpieczeństwa teleinformatycznego nie obejmuje analizy kontroli finansowych i operacyjnych oraz transakcji pod kątem ewentualnych nadużyć i oszustw popełnianych przez uprawnionych użytkowników systemów teleinformatycznych, chociaż procedury nadawania uprawnień i bezpieczeństwo osobowe (razem zawierające zwykle podatności systemu na nadużycia popełniane przez uprawnionych użytkowników) są obiektami badania.
- Audyt bezpieczeństwa teleinformatycznego nie obejmuje wykonania inwentaryzacji zasobów teleinformatycznych, chociaż może obejmować (i zwykle obejmuje) sprawdzenie rzetelności posiadanych przez audytowaną organizację spisów zasobów teleinformatycznych. Dotyczy to także audytu informatycznego.

Warto zauważyć, że audyt to **sprawdzenie i ocena, a nie wykonanie czegoś (np. spisu inwentaryzacyjnego).** Dlatego nieporozumieniem jest łączenie audytu z wykonaniem inwentaryzacji zasobów informatycznych, chociaż w ramach audytu, zarówno informatycznego, jak i bezpieczeństwa teleinformatycznego, jest sprawdzane posiadanie przez audytowaną organizację rzetelnych spisów inwentaryzacyjnych. Wykonywanie takich spisów przez audytorów oznacza, że będą sprawdzali także wykonaną przez siebie pracę, co przeczy podstawowym zasadom audytu.

Audyt bezpieczeństwa teleinformatycznego

Audyt bezpieczeństwa teleinformatycznego składa się zazwyczaj z dwóch głównych części. Najpierw wykonywany jest audyt przygotowanej dokumentacji systemu zarządzania bezpieczeństwem informacji (pl. *SZBI*, ang. *ISMS*). Po nim następuje audyt zaimplementowanych elementów dokumentacji. Po wykonaniu audytu dokumentacji, kierownik zespołu audytorskiego tworzy pisemny raport, w którym zawiera najważniejsze spostrzeżenia z właśnie ukończonego etapu i wyjaśnia szczegóły następnego etapu audytu. Druga faza audytu powinna zostać rozpoczęta w przeciągu ustalonego przedziału czasu, np. trzech do sześciu tygodni po audycie dokumentacji. Jeżeli przerwa przekroczy ustalony przedział czasu, należy powtórzyć pierwszą fazę.

Audyt może się zakończyć wnioskami z audytu lub wystawieniem certyfikatu na zgodność z obowiązującymi normami, o ile audyt prowadziła jednostka do tego upoważniona (w Polsce PKN lub inna delegowana) a zainteresowana strona wnioskowała o taki certyfikat.



Audyt bezpieczeństwa teleinformatycznego

Dobrym wzorcem dla audytu bezpieczeństwa jest standard: stanowi rodzaj *checklisty,* dając wektorową miarę bezpieczeństwa, zapewnia, że nic, co uznano za istotne, nie zostanie pominięte. Umożliwia także powtarzalność badań.

Spośród wzorców największe znaczenie mają:

- Norma ISO/IEC 27007: Wytyczne do audytu
- Dokumenty wydawane przez stowarzyszenie ISACA (*Information Systems Audit and Control Association - Stowarzyszenie ds. audytu i kontroli systemów informatycznych*; obecnie używa jedynie akronimu ISACA), szczególnie tzw. zbiór dobrych praktyk (ang. *Framwor*k) znany pod nazwą COBIT (od 2017 wydawana jest wersja 5.x tego dokumentu).

Warto zauważyć, że stowarzyszenie ISACA liczy ponad 120 000 członków i sympatyków, których cechuje duża różnorodność. Mieszkają i pracują w ponad 180 krajach i zajmują wiele różnych stanowisk związanych z sektorem IT - są m.in. audytorami systemów informatycznych, konsultantami, wykładowcami, specjalistami ds. bezpieczeństwa, osobami nadzorującymi tworzenie i przestrzeganie przepisów prawa, szefami działów informatyki i audytorami wewnętrznymi.

Działania ISACA koncentrują się na zagadnieniach audytu i bezpieczeństwa systemów informacyjnych oraz tzw. ładu informatycznego.

Audyt bezpieczeństwa teleinformatycznego

Uzupełnieniem norm i standardów wymienionych w czasie zajęć, przydatnych nie tylko w celach audytu, są inne dokumenty, zwłaszcza dokumenty NIST serii 800. Są to tzw. Special Publications, (SP), które są uważane za wzorcowe (tj. standardy „de facto", nie tylko w USA), chociaż nie są to standardy „de jure". Ze względu na dynamikę zmian ich treści przy nazwach nie podano numeru wersji.

- SP 800-12: *An Introduction to Information Security.*
- SP 800-30*: Guide for Conducting Risk Assessments*.
- SP-800-39: *Managing Risk from Information Systems. An Organizational Perspective.*
- SP-800-50: *Building an Information Technology Security Awareness and Training Program.*
- SP-800-53: *Recommended Security Controls for Federal Information System; Guide for Assessing the Security Controls in Federal Information Systems. Building Effective Security Assessment Plans.*
- SP-800-60: *Guide for Mapping Types of Information and Information Systems to Security Categories.* Vol. I, II.
- SP-800-61: *Computer Security Incident Handling Guide.*
- SP-800-64: *Security Considerations in the Information System Development Life Cycle.*
- SP-800-82: *Guide to Industrial Control Systems (ICS) Security.*
- SP-800-86: Guide to Computer and NetWork Data Analysis: *Applying Forensic Techniąues to Incident Response.*
- SP-800-92: *Guide to Computer Security Log Management.*
- SP-800-95: *Guide to Secure Web Services.*
- SP-800-115: *Technical Guide to Information Security Testing.*

Audyt bezpieczeństwa teleinformatycznego

W odróżnieniu od ogólnych norm ISO/IEC standardy NIST są bardziej techniczne i szczegółowe. Mimo ich przeznaczenia dla administracji federalnej USA, ich zalecenia można z powodzeniem stosować także w innych krajach. Szczególną uwagę należy zachować przy odwołaniach dokumentów NIST do przepisów prawa USA lub do innych dokumentów niekoniecznie uznawanych przez inne kraje.

Osoby budujące systemy zabezpieczeń powinny przede wszystkim zapoznać się z zaleceniami zawartymi w **SP 800-53.** Natomiast osobom, które chcą sobie wyrobić pogląd na temat zakresu przedsięwzięć związanych z zapewnianiem szeroko rozumianego bezpieczeństwa teleinformatycznego (i jednocześnie zakresem dostępnych publikacji NIST), a nie mają czasu na studiowanie wszystkich dokumentów serii SP-800, poleca się publikację **SP 800-12.** Dokument zawiera przegląd takich przedsięwzięć wraz z odsyłaczami do innych publikacji tej serii, w których poszczególne zagadnienia są szczegółowo opisane [3].

Bibliografia:

1. A. Białas, *Bezpieczeństwo informacji i usług w nowoczesnej instytucji i firmie*, WNT, Warszawa, 2007.
2. K. Liderman, *Analiza ryzyka i ochrona informacji w systemach komputerowych*, PWN, Warszawa, 2008.
3. K. Liderman, *Bezpieczeństwo informacyjne, nowe wyzwania*, PWN, 2017.
4. R. Andersson, *Inżynieria zabezpieczeń*, WNT, 2005.
5. J. Stokłosa, T. Bilski, T. Pankowski, *Bezpieczeństwo danych w systemach informacyjnych*, PWN, 2001.
6. Materiały firmowe/Internet.

KONIEC CZĘŚCI II